Unidad VI - Seguridad y Auditoría de Sistemas de Información

Administración de Sistemas de Información

n1krov, Juani, Pollo y Chipancho

3 de noviembre de 2026

Índice

1. Control del Ambiente Informático **4**

2. Management Responsable de IS **4**

3. Manejo de la seguridad de los SI **5**

3.1. Etapas de la Administración de Riesgos . . . 7
3.1.1. Identificación del riesgo . . . 7
3.1.1.1. Definiciones . . . 8
3.1.2. Análisis del riesgo . . . 10
3.1.3. Manejo del riesgo . . . 13
3.1.3.1. Controles y contramedidas . . . 15
3.1.4. Recuperación ante el desastre . . . 17
3.1.4.1. Evaluación de riesgos . . . 19
3.1.4.2. Formulación de un Plan de Contingencias . . . 19
3.1.4.3. Metodologías de recuperación . . . 20
3.1.4.4. Técnicas de auditoría y funciones del auditor en la continuidad de las operaciones . . . 21
3.2. Política de seguridad . . . 21
3.2.1. Definición de política . . . 23
3.2.2. Ciclo de vida de una política . . . 24
3.3. Clasificación y tipos de ataques contra sistemas de información . . . 25

4. Auditoría **26**

4.1. Auditoría de sistemas/informática (Lardent) . . . 27
4.1.1. Aspectos a revisar por la auditoría de sistemas (áreas) . . . 28
4.2. Control interno . . . 29
4.2.1. Categorías de controles (Lardent) . . . 29
4.2.2. Implantación de un Sistema de Control Informático Interno (Piattini) . . . 29
4.2.3. Auditoría informática vs. Control Interno Informático (Piattini) . . . 31
4.3. Control interno informático (Piattini) . . . 32
4.3.1. Similitudes y diferencias entre control interno informático y auditor informático interno . . . 33
4.4. Etapas de la auditoría . . . 33
4.5. Programa de revisión . . . 34

4.6. **Pasos para la ejecución de una auditoría de sistemas de información** . . . 35
4.6.1. Evaluación de riesgos globales . . . 36
4.6.2. Desarrollo del programa de auditoría . . . 36
4.7. La importancia de los procedimientos (Soria Ojeda) . . . 37
4.8. Evidencia en la auditoría . . . 38
4.9. Tipos de pruebas . . . 39
4.10. Objetos (secciones de la auditoría de sistemas) . . . 39
4.11. Deontología (reglas éticas) del auditor . . . 39
4.12. Auditoría interna . . . 40
4.13. **Auditoría externa** . . . 40
4.14. Comparación entre el control interno, auditoría interna y externa informática . . . 41
4.15. Informes de auditoría . . . 42
4.15.1. Estructura básica de un informe de auditoría (Lardent) . . . 42
4.15.2. Tipos de informes (Lardent) . . . 43
4.16. Auditoría de la Función Informática (Auditoría de Organización y Administración del Ambiente Informático) . . . 43
4.17. Auditoría del Desarrollo de Sistemas . . . 44
4.18. Auditoría de Sistemas de Aplicación Instalados . . . 46
4.19. Auditoría de Seguridad . . . 47
4.20. Técnicas de evaluación y auditoría . . . 48
4.21. Apuntes de clase (videos) . . . 48
4.21.1. Definición y finalidad . . . 48
4.21.2. Aspectos clave de la auditoría de sistemas . . . 50
4.21.3. Control interno . . . 51
4.21.4. Implantación de Sistema de controles internos . . . 51
4.21.5. Tipos de auditorías . . . 52
4.21.6. Comparación entre el control interno, auditoría interna informática y auditoría externa informática . . . 52
4.21.7. Aspectos procedimentales claves de la auditoría - etapas de la auditoría . . . 53
4.21.7.1. Cómo se hace el plan de auditoría . . . 53
4.21.8. Importancia de procedimientos . . . 56
4.21.9. Tipos de prueba . . . 56
4.21.10. Objetos (secciones) o áreas de la auditoría informática . . . 56
4.21.11. Riesgos del auditor (Etapa inicial) . . . 57
4.21.11.1. Cuadro comparativo para distinguirlos rápido . . . 57
4.21.12. Deontología . . . 58
4.21.13. ¿Por qué auditar desarrollo? . . . 59
4.21.14. La auditoría en el área de desarrollo (Lardent y Piattini) . . . 59
4.21.15. Niveles de emergencia planteados por Lardent . . . 61
4.21.16. Taller de Laboratorio asociado . . . 61

5. Extras **62**
5.1. Cuestionario Parte I - Seguridad de SI/TI . . . 62
5.1.1. 1. ¿Qué es el delito informático? . . . 62
5.1.2. 2. ¿Quiénes son sus artífices (sujetos activos)? . . . 63
5.1.3. 3. ¿Con qué modalidad operan? . . . 63
5.1.3.1. A. Modalidades generales de ataque al flujo de información . . . 64
5.1.3.2. B. Técnicas específicas para cometer delitos informáticos (Lardent) . . . 64
5.2. Cuestionario Parte II. Auditoría de SI/TI . . . 65
5.2.1. ¿Qué es la auditoría de sistemas de información? . . . 65
5.2.2. ¿Qué es el control interno? Desarrolle las clasificaciones de control. Ejemplifique cada una. . . . 65

5.2.3. ¿Cuáles son los tipos de prueba que se requieren en la Auditoría de SI? 66
5.2.4. Para cada área de Auditoría determine: i. Concepto; ii. Funciones del Auditor; iii. Síntesis de los elementos a auditar 66
5.2.4.1. Auditoría de Sistemas de Información (Capítulo 20) 66
5.2.4.2. Auditoría de Organización y Administración del Ambiente Informático (Capítulo 21) 67
5.2.4.3. Controles de Accesos Lógicos y Físicos (Capítulo 22) 67
5.2.4.4. Seguridad en los sistemas de base de datos (Capítulo 23) 68
5.2.4.5. Seguridad de redes y sistemas distribuidos (Capítulo 24) 68
5.2.4.6. Auditoría de sistemas (Capítulo 25) 68
5.2.4.7. Auditoría del desarrollo de sistemas (Capítulo 23 en el índice y en el texto) 69
5.2.4.8. Auditoría de adquisición de software (Capítulo 26 en el texto) 69
5.2.4.9. Auditoría de modificaciones a programas (Capítulo 26 en el texto) . . 69
5.2.4.10. Auditoría de sistemas instalados de aplicación (Capítulo 26 en el texto) 70
5.2.4.11. Auditoría de control de entrada de datos (dentro del Capítulo 26, página 382) 70
5.2.5. Auditoría del desarrollo: efectúe un cuadro comparativo entre el enfoque de Lardent y el de Piattini & Del Peso 70
5.2.5.1. Cuadro comparativo: Auditoría del Desarrollo de Sistemas (Lardent vs. Piattini & Del Peso) 71
5.2.5.1.1. Síntesis para recordar en el examen 73

1. Control del Ambiente Informático

Es el conjunto conformado por la **seguridad, la auditoría y los controles** aplicados sobre el área de SI y sus recursos, así como sobre todos los sectores asociados al procesamiento de información de la organización.

El **ambiente informático** no involucra solo al departamento de procesamiento de datos, sino también **a todos aquellos sectores de la organización que estén asociados con él**, ya sea porque le proveen datos para procesar, porque son usuarios de la información procesada o porque procesan información localmente y proveen datos de resumen al procesador central.

El ambiente informático se controla como medida de **prevención de riesgos**, a fin de evitar posibles pérdidas para la organización. Además, se debe controlar que todas las actividades se efectúen de acuerdo con los procedimientos y normas fijados, y comprobar que se logren los niveles de servicio adecuados.

Los **procesos de control del ambiente informático** son las herramientas que garantizan que las tecnologías y las áreas relacionadas con el procesamiento de la información funcionen adecuadamente. Cualquier punto en el que se procese información, aunque sea en papel, debe cumplir con las pautas de estos procesos de control.

Los procesos de control del ambiente informático son la **gestión de la seguridad de los SI/TI y la auditoría de los SI/TI.**

2. Management Responsable de IS

> *Robson, capítulo 13.*

La gestión o management de la seguridad del ambiente informático consiste en administrar los SI/TI de un «modo seguro». Cuando hablamos de IS seguros, nos referimos a los siguientes aspectos.

> **¿Qué cuestiones determinan el management de los SI de un modo «seguro»?**

1. «Seguros» desde un punto de vista organizacional, es decir, **técnico**.
    - ***Aquí se usan herramientas. Las fuentes de datos (formularios) y los procedimientos internos forman parte de este aspecto.***
2. «Seguros» desde un punto de vista social, es decir, **ético**.
3. «Seguros» desde un punto de vista judicial, es decir, **legal**.
    - ***Por ejemplo: ¿cuáles son los requisitos legales para ciertos procedimientos?***

El entorno organizacional debe pensarse y diseñarse para que todo siga siendo seguro.

Estos tres puntos —el ético, el legal y el que hace a la seguridad— se superponen. Es frecuente que existan obligaciones legales y morales en relación con la seguridad de la información y con su almacenamiento, procesamiento y recuperación. El marco legislativo actual de los SI codifica una perspectiva social de lo

que es correcto, es decir, de la ética. Mantener la seguridad de los SI puede plantear dilemas legales y éticos.

3. Manejo de la seguridad de los SI

Se procederá al análisis desde el punto de vista técnico.

La gestión de la seguridad del ambiente informático implica gestionar los recursos de SI/TI de un modo responsable.

> **¿Qué es la pérdida de seguridad? Cuando esta ocurre, ¿cuáles son los aspectos involucrados?**

Este aspecto se refiere a la visualización y el management de los riesgos en términos de sus causas, sus efectos y, por lo tanto, los costos que implica una **pérdida de seguridad**. Esta puede definirse como «***la falla de los elementos de un sistema de información computarizado para realizar la función o brindar el o los servicios para los cuales estaba destinado***».

Dicha falla es una pérdida de uno o más de los siguientes **tres aspectos** desde el punto de vista técnico (o de todos ellos):

1. **Integridad de la información**: la pérdida de seguridad destruye la capacidad de una empresa para confiar en sus datos o, peor aún, la deja con datos de precisión incierta.
2. **Operatividad/disponibilidad**: la pérdida de seguridad destruye, total o parcialmente, la capacidad de la empresa para acceder a datos e información.
3. **Confidencialidad**: la pérdida de seguridad destruye la posesión exclusiva de los datos, lo que provoca que la organización pierda poder y confianza. También implica que cada rol acceda solo a la información que le corresponde según sus responsabilidades organizacionales.

La pérdida de un aspecto puede impactar en los demás.

> **¿Qué es la administración del riesgo? ¿Cómo se relaciona este concepto con la seguridad?**

De esta definición se desprende que las organizaciones necesitan **administrar el riesgo** de exposición de cada uno de los elementos de los IS. **Este management deberá considerar el equilibrio entre los costos resultantes de una falla de seguridad y los costos de las medidas necesarias para aumentar la seguridad.** El punto central es identificar el equilibrio óptimo.

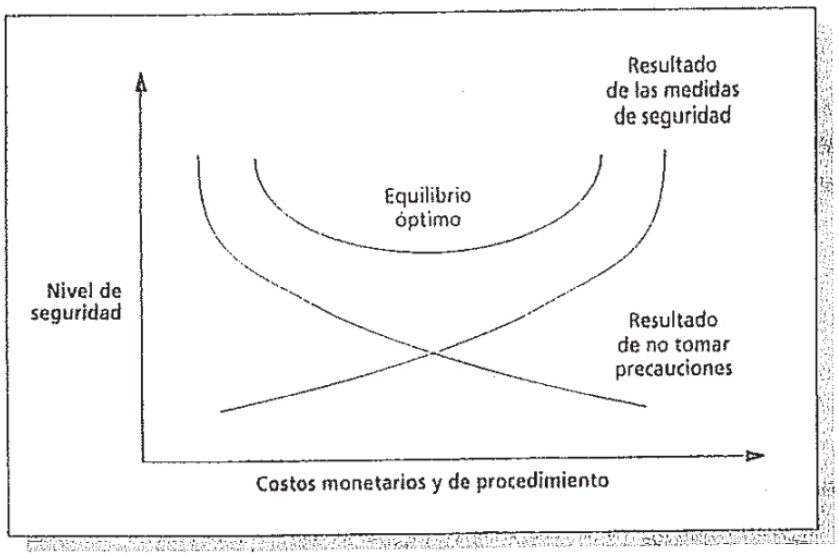


Figura 13.1. El equilibrio de los costos de seguridad.

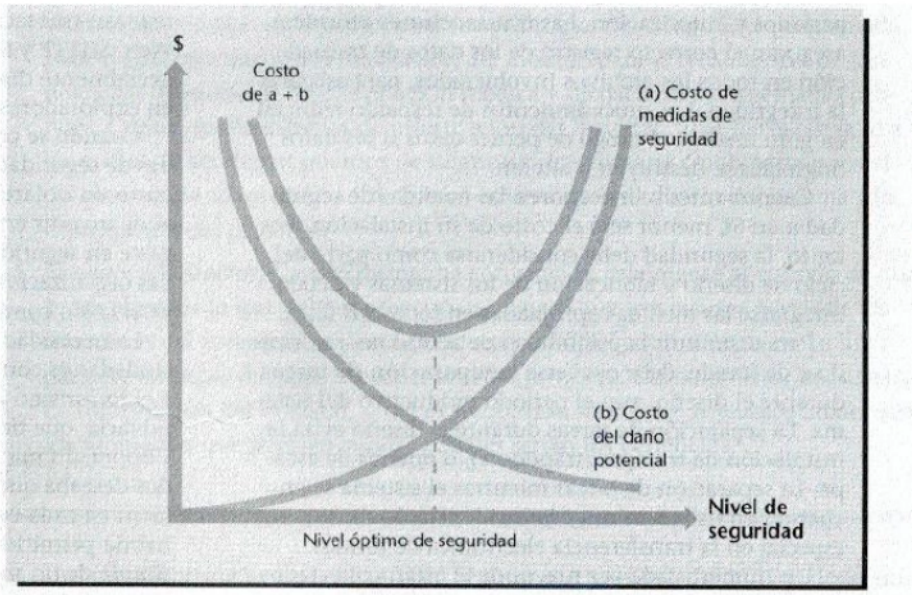


Figura 17.14 *El costo total para la empresa es más bajo en el punto "óptimo". No debe gastarse ni menos ni más en medidas de seguridad de información*

El costo de no tener seguridad puede ser difícil de definir, aun cuando las fallas ocurran. El management del riesgo intenta reducir estas pérdidas. **Un enfoque sistemático del management del riesgo permitirá administrar la seguridad de los IS reconociendo la vulnerabilidad y la sensibilidad de los sistemas de la empresa y de los datos que contienen, pero también los costos de los controles y de las medidas para el manejo de riesgos. Ningún sistema puede ser completamente seguro.** El management permite elegir e implementar las contramedidas de forma planificada y administrada.

No se administra la seguridad en sí, sino el nivel de riesgo: cuanto menor es el nivel de riesgo, mayor es la seguridad. Se analizan y evalúan medidas sobre el riesgo.

Premisas:

- ***La seguridad total es imposible.*** NUNCA se alcanza el 100 % de seguridad; solo se logra un nivel razonable.
- ***Mejor manejo del riesgo.*** Se busca el equilibrio entre los costos resultantes de una falla y los costos de las medidas necesarias para aumentar la seguridad.

3.1. Etapas de la Administración de Riesgos

El management de la seguridad de SI se reduce a una metodología de **cuatro pasos genéricos**:

1. Identificación del riesgo.
2. Análisis del riesgo.
3. Manejo del riesgo.
4. Recuperación del desastre.

> **Enumerar y sintetizar las etapas de la administración del riesgo.** → Están enumeradas arriba; la explicación de cada una se desarrolla a continuación.

3.1.1. Identificación del riesgo

El primer paso es identificar «todos» los riesgos a los que es vulnerable un sistema particular, un conjunto de sistemas, una función o una empresa. Para realizar esta tarea se necesitan dos cosas: **un conocimiento bastante detallado del trabajo de la organización** y un **reconocimiento de las áreas que tienden a la vulnerabilidad**. Esta segunda parte —la comprensión del riesgo probable— puede llevarse a cabo mediante consultores externos, pero la identificación de las amenazas específicas probablemente la realicen mejor el personal o los consultores internos. ***Los consultores externos ofrecen un amplio conocimiento, mientras que el personal interno ofrece una profunda comprensión de la empresa.***

Se trata de encontrar los puntos débiles, es decir, todo aquello a lo que está potencialmente expuesto el ambiente informático. Se debe identificar, ***en ORDEN***:

1. Los **activos** que se deben proteger y que son vulnerables a la pérdida.
2. La ubicación de los riesgos (¿dónde están?) y las **vulnerabilidades** potenciales (¿cuáles tienen?).
3. Las fuentes de **amenazas** potenciales.

> **Nota...**
>
> **Esto se puede expresar en una oración:** tengo este ***activo*** con esta ***vulnerabilidad***, que, como consecuencia, puede sufrir esta ***amenaza***.

3.1.1.1. Definiciones

Amenaza: **condición del entorno del sistema de información** (persona, máquina, suceso o idea) **que, dada una oportunidad, podría dar lugar a una violación de seguridad** (confidencialidad, integridad, disponibilidad, autenticidad, no repudio). **Es algo con capacidad de daño.** Un **ataque** es la realización de una amenaza.

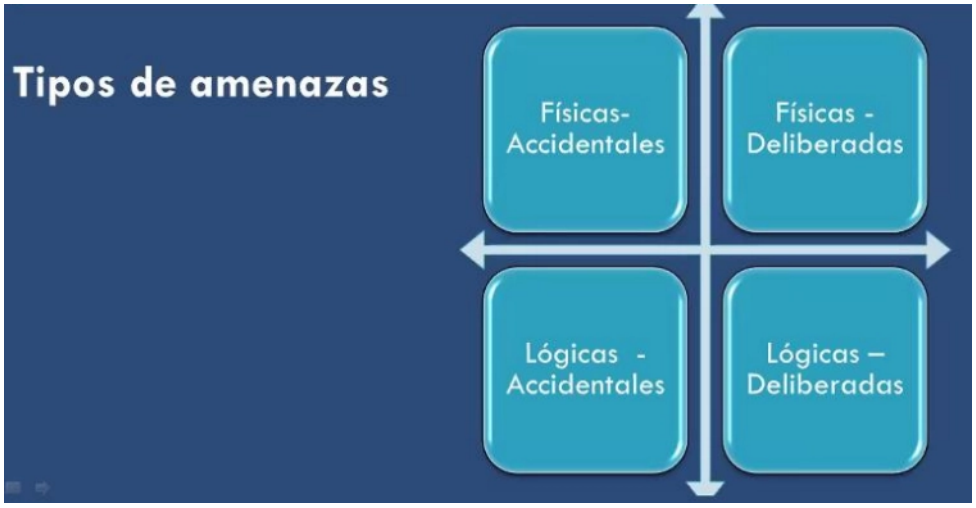
Las amenazas pueden afectar la disponibilidad (interrupción), la integridad (modificación) o la confidencialidad (intercepción).

Existen distintos **tipos de amenazas**:

- Físicas o lógicas.
- Accidentales o deliberadas.

La vulnerabilidad de un área en particular depende de los siguientes factores:

- El personal de la organización.
- El tamaño de la red.
- La calidad de la transmisión de datos.



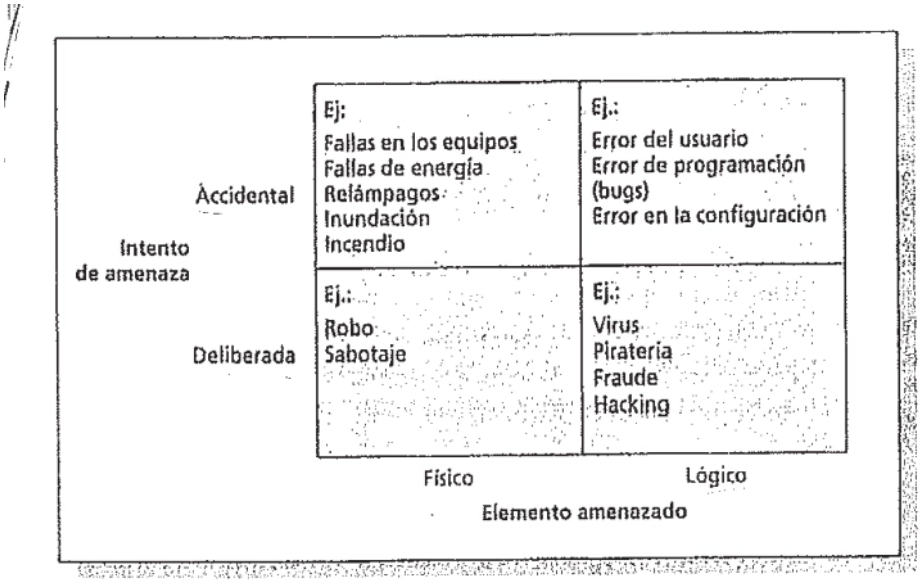


Figura 13.3. Lista de identificación de amenazas.

Los activos vulnerables a pérdidas debido a una amenaza pueden ser:

- **Hardware**: su pérdida es relativamente fácil de evaluar, y estos elementos suelen estar asegurados.
- **Software**: la principal complicación al evaluar su pérdida es que el valor intrínseco o el costo de reemplazo del software no tiene relación con su costo original de desarrollo. Además, la pérdida de software genera una pérdida de capacidad de procesamiento, por lo que ese factor debe incluirse en la cuantificación de la pérdida del software.
- **Datos e información**: es la pérdida más seria y la más difícil de cuantificar.
- **Capacidad de procesamiento**: la duración de la interrupción es la variable clave para determinar el valor de la pérdida.
- **Personal**: esta pérdida puede ser significativa, ya sea por su conocimiento teórico o por su competencia práctica.
- **Fondos.**

Riesgo: es el potencial de que una amenaza determinada explote las vulnerabilidades de un activo o de un grupo de activos y ocasione su pérdida o daño (ISACA).

El concepto de riesgo está relacionado con el de materialidad, que se refiere a la magnitud del error en términos de su impacto potencial para el conjunto de la organización. En general, esa materialidad se expresa en términos monetarios.

Elementos del riesgo:

- **Activos**: información, datos, hardware, software, servicios, documentos, personal, etc.
- **Amenazas**: son el resultado de un análisis de vulnerabilidades; por ejemplo, errores, ataques maliciosos, fraude, robo, fallas de equipos o fallas de software.

- **Vulnerabilidades**: lo que es atacable; por ejemplo, la falta de conocimientos del usuario, la falta de funcionalidad de seguridad, la mala elección de contraseñas, la tecnología no probada o las transmisiones no seguras.
- **Impactos**: son las pérdidas que resultan de la ocurrencia de una amenaza: pérdida directa de dinero, violación de leyes, pérdida de reputación, violación de la confianza, pérdida de oportunidades de negocio, reducción de la eficiencia e interrupción de las actividades del negocio.
- **Riesgo Global**: una vez establecidos los elementos del riesgo, estos se combinan para formar el carácter global del riesgo (cálculo del impacto y la probabilidad de cada amenaza).
- **Riesgo Residual**: es el nivel de riesgo que queda una vez aplicados los controles. La gerencia puede utilizarlo para identificar las áreas en las que se requiere más control para reducir aún más los riesgos, o bien para identificar puntos de control que estén sobrecontrolados.

3.1.2. Análisis del riesgo

> Una vez identificados los riesgos, se debe cuantificar la probabilidad y la frecuencia esperada de ocurrencia de cada uno.

En esta etapa se relacionan los activos, las vulnerabilidades y los lugares en que se producen, para poder formular, expresar y calcular el riesgo. Aquí se le asigna un valor monetario a lo que ocurriría si el riesgo se materializa.

Una vez detectadas las amenazas, se puede analizar su **impacto potencial**. Si la etapa de identificación constituye una forma de «pensamiento creativo y espontáneo», la etapa de análisis del riesgo es un proceso más estructurado, aunque a menudo cualitativo y no cuantitativo. **Consiste en analizar el impacto potencial para determinar la pérdida esperada que produciría una amenaza particular**, donde:

$$\text{Pérdida esperada} = \text{Pérdida potencial (\$)} \times \text{Frecuencia de pérdida}$$

Y donde:

$$\text{Frecuencia de pérdida} = \text{Probabilidad de agresión} \times \text{Probabilidad de éxito (del ataque)}$$

El análisis del impacto potencial (es decir, para cada riesgo identificado, la probabilidad de ocurrencia y la gravedad de sus consecuencias) requiere **dos etapas**:

1. La primera evalúa los costos empresariales que surgen de una brecha de seguridad. Esta evaluación debería incluir, al menos de modo aproximado, cálculos financieros, incluso para los costos conceptuales. Existe un gran número de aspectos relacionados con las pérdidas potenciales provenientes de una falla de seguridad.

2. A esto se le suma la posibilidad calculada de que suceda: la segunda etapa consiste en estimar la frecuencia de ocurrencia de cualquier falla de seguridad a partir de la probabilidad de agresión y de la probabilidad de que la agresión prospere (se entiende por agresión cualquier falla en la seguridad, no necesariamente un abuso humano deliberado).

Amenaza	Probabilidad de agresión		× Probabilidad de éxito		= Frecuencia
Entrada de datos incorrecta	muy alta	90%	mediana	50%	45%
Incendio	mediana	50%	alta	70%	35%
Hacking	baja	20%	mediana	50%	10%

Nota: la reducción del riesgo discutida en la Sección 13.1.3 puede disminuir la probabilidad de agresión o la probabilidad de éxito a fin de reducir la frecuencia; puede también reducir los costos resultantes para disminuir la pérdida general.

Figura 13.6. Cálculos de frecuencia de amenazas.

El producto del costo y la frecuencia da como resultado la pérdida anual esperada para cada amenaza:

Costo (de las consecuencias) × Frecuencia (de los cálculos) = Exposición anual de pérdidas

El análisis del riesgo establece uno de los lados del punto de equilibrio óptimo entre el costo de las pérdidas y el costo de las medidas de seguridad. El manejo del riesgo identifica las contramedidas posibles y luego elige el conjunto adecuado para lograr ese equilibrio óptimo.

Un análisis de riesgo efectivo requiere apreciar la verdadera magnitud de las pérdidas resultantes de cada amenaza, lo cual es difícil de determinar. El management efectivo del riesgo también requiere una valoración realista de la posibilidad de que la amenaza se concrete.

Todas las pérdidas que resultan de una falla de seguridad se relacionan con los atributos de valor agregado de la información y pueden dividirse en tres categorías:

1. **Pérdida de disponibilidad**: la pérdida de seguridad destruye, total o parcialmente, la capacidad de la empresa para acceder a datos e información.
2. **Falla en la integridad/precisión**: la pérdida de seguridad destruye la capacidad de una empresa para confiar en sus datos o, peor aún, la deja con datos de precisión incierta.
3. **Pérdida de confidencialidad/seguridad**: la pérdida de seguridad destruye la posesión exclusiva de los datos, lo que provoca que la organización pierda poder y confianza. Una vez más, el peor caso es el de la incertidumbre.

Para evaluar la magnitud de la pérdida resultante de una falla de seguridad se deben considerar las **pérdidas directas (o consecuencias primarias)**, es decir, aquellas que se desprenden directamente —y, por lo general, de forma inmediata— de un problema de seguridad.

Ejemplos de pérdida directa:

- Interrupción del procesamiento a corto o largo plazo.
- Corrupción de los registros de datos, que a menudo incluyen material de backup; el peor caso es cuando la corrupción no se detecta o cuando su alcance es incierto.
- Destrucción de los medios de almacenamiento.
- Uso de software no autorizado; en el mejor de los casos, atasca las redes y reduce la capacidad de procesamiento; en el peor de los casos, los sistemas se destruyen y los fondos son mal dirigidos.
- Revelación de información confidencial.
- Desaparición de equipos, datos o software; el robo o la piratería son difíciles de reconocer.
- Pérdida de los registros de contabilidad u otros; en el mejor de los casos, esto perjudica el análisis histórico; en el peor de los casos, significa el detenimiento de los recibos de efectivo.

Figura 1: *Consecuencias primarias.*

No todas las pérdidas empresariales son el resultado directo de una falla de seguridad. Las **pérdidas secundarias** (que surgen como consecuencia de las pérdidas primarias y no de la falla en sí misma) tienen gran importancia en el cálculo de las pérdidas.

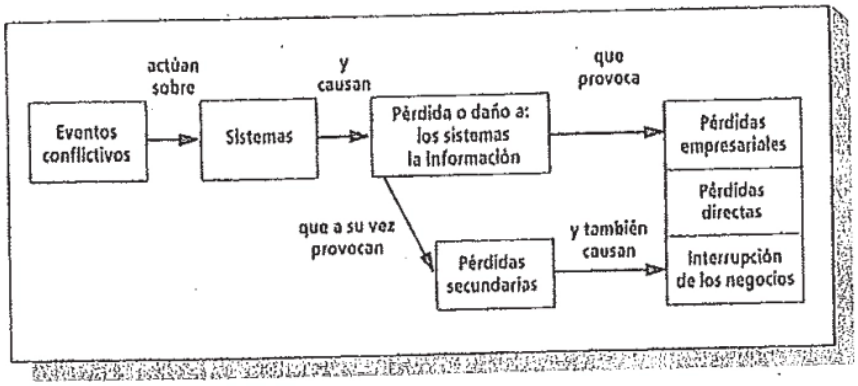


Figura 13.10. Pérdidas resultantes de una falla en la seguridad.

Si las consecuencias primarias son difíciles de cuantificar, aún más difícil es evaluar las secundarias, que tienden a ser más costosas que las pérdidas directas y, como son costos empresariales, por lo general aparecen después de un largo tiempo. Pocas veces resulta práctico asignar valores monetarios detallados a las consecuencias secundarias; en su lugar, se utilizan clasificaciones cualitativas.

Ejemplos de pérdidas secundarias:

- Pérdida en la producción
- Retraso en las entregas
- Problemas de flujo de efectivo
- Pérdida de confianza del cliente
- Declaraciones de impuesto imprecisas
- Información gerencial inútil, imprecisa e inoportuna
- Sanciones por incumplimiento de obligaciones legales
- Incapacidad de continuar la función del sistema
- Pérdida de una posición competitiva
- Incapacidad de continuar con el negocio

Figura 13.11. Consecuencias secundarias de una falla en la seguridad.

Figura 2: *Consecuencias secundarias.*

La magnitud de la pérdida total de una falla de seguridad es la suma de las consecuencias primarias y secundarias. Si se logran minimizar las consecuencias primarias, la ganancia es doble, porque al reducirse las pérdidas primarias también se minimizan las secundarias.

Ejemplos:

Consecuencias primarias	Consecuencias secundarias
Interrupción del procesamiento a corto o largo plazo	Pérdida en la producción
Corrupción de los registros de datos	Retraso en las entregas
Destrucción de los medios de almacenamiento	Problemas de flujo de efectivo
Uso de software no autorizado	Pérdida de confianza del cliente
Revelación de información confidencial	Declaraciones de impuestos imprecisas
Desaparición de equipos, datos o software	Información gerencial inútil, imprecisa e inoportuna
Pérdida de los registros de contabilidad u otros	Sanciones por incumplimiento de obligaciones legales
	Incapacidad de continuar con la función del sistema
	Pérdida de una posición competitiva
	Incapacidad de continuar con el negocio

3.1.3. Manejo del riesgo

> ***El resultado de la etapa 2 sirve como insumo para decidir qué estrategia de manejo del riesgo utilizar.***

La identificación y el análisis de las amenazas se realizan con el objetivo de implementar estrategias adecuadas que ofrezcan la mejor **efectividad** neta, es decir, que mantengan el equilibrio deseado. **Cualquier medida es más barata que perder los datos.**

El manejo del riesgo consiste en aplicar **controles y contramedidas** apropiados para el riesgo, de acuerdo con el tiempo, el dinero y otras restricciones. Los pasos previos:

1. Enumeración de las amenazas potenciales.
2. Cuantificación de las pérdidas que surgen como consecuencia de las amenazas exitosas.
3. Determinación de la ALE (tabla de pérdida anual) o de alguna otra medida de la probabilidad o la gravedad de ocurrencia.

Constituyen un proceso valioso, pero solo como un medio para alcanzar un fin. El propósito es identificar el «mejor» método de manejo del riesgo, entendiendo por «mejor» un management de las fallas potenciales de seguridad que sea efectivo en cuanto al costo. Existen cuatro **estrategias genéricas para el manejo del riesgo**:

1. **Prevenir el riesgo**: son medidas para **intentar evitar la amenaza**. Por ejemplo: colocar los sistemas lejos de las áreas peligrosas, ubicar los datos delicados en áreas protegidas, no descentralizar, usar ANTIVIRUS, etc.
2. **Asumir el riesgo**: se utiliza cuando las pérdidas totales (la suma de las consecuencias primarias y secundarias) son tolerables para la organización. También debe tenerse en cuenta la probabilidad de ocurrencia.

   > ***Es cuando podemos afrontar la pérdida esperada de un activo.***

3. **Reducir el riesgo**: resulta difícil evitar por completo el riesgo y, a veces, es inadecuado ignorarlo. Consiste en introducir controles y contramedidas para **reducir la probabilidad de ocurrencia o las pérdidas resultantes** de una falla de seguridad. Por ejemplo, el *backup*.

   > ***Controles que permiten reducir las pérdidas.***

4. **Transferir el riesgo**: **traslada a un tercero los costos resultantes de una falla de seguridad**; en general, implica pólizas de seguro o contratos de mantenimiento.

> Por cada riesgo se debe pensar una sola estrategia; las estrategias indican en qué se pondrá más foco al invertir en seguridad.

> **Nota…**
>
> La transferencia del riesgo, por lo general mediante la contratación de un seguro, resulta apropiada para las amenazas de **alto costo y baja probabilidad**, en las que la recuperación es casi imposible.

Identificar un *portfolio* de management del riesgo significa seleccionar un conjunto heterogéneo de estrategias de manejo del riesgo que dependen de la aplicación sistemática de la identificación y el análisis del riesgo.

Cada vez más, la seguridad de los SI debe considerarse un tema estratégico, y toda empresa debería invertir en ella. Si el resultado de las pérdidas prevenidas o reducidas es mayor que el costo de la seguridad, existe una contribución neta a las ganancias.

Una **política de seguridad** define el nivel de seguridad que se ajusta al valor de lo que se debe proteger y al gasto y la inconveniencia de las medidas de protección. Estas políticas documentan el resultado de la identificación y el análisis del riesgo, y las estrategias elegidas para manejarlo. El documento debe cubrir, al menos:

- **La protección de la información**, dado que la naturaleza de la información determina su atractivo externo y su importancia interna.
- **El valor de la información**, ya que cuantifica las pérdidas potenciales.
- **El acceso a la información**, porque define quién está autorizado para ver, modificar, cargar o descargar los datos.
- **La recuperación de la información**, porque define cómo pueden recuperarse y volver a utilizarse los datos perdidos o dañados.

Tipos de políticas de seguridad:

- **Permisiva**: expresa lo que está particularmente prohibido; da más libertad o mayor amparo, ya que lo que no está expresamente prohibido está permitido.
- **Prohibitiva**: lo que no está expresamente permitido está prohibido (es mucho más restringida).

3.1.3.1. Controles y contramedidas

Las estrategias de manejo del riesgo se implementan a través de **controles y contramedidas**. La elección del conjunto que, de un modo efectivo con respecto al costo, evita, reduce o transfiere el impacto del riesgo es, obviamente, un aspecto del management del riesgo. Asimismo, los controles y las contramedidas se relacionan básicamente con las estrategias de **prevención y reducción** del riesgo. Las medidas de seguridad y control deben considerarse en términos de sus costos netos y de los nuevos riesgos potenciales que genera su adopción.

Existen fundamentalmente dos tipos de control:

- Las **contramedidas generales** ***(se introducen ante la ocurrencia de la amenaza)***, que se introducen para reducir la amenaza sobre todas las actividades de los SI dentro de una organización. Un punto débil en los controles generales podría provocar una pérdida de seguridad en cualquier sistema; por eso, el costo de estas medidas debería considerarse «compartido» por todas las áreas protegidas.
- Los **controles de aplicación**, diseñados para proteger de amenazas un área específica. Hasta cierto punto, para la mayoría de las empresas, los controles de aplicación son un conjunto de controles generales.

> **Nota de clase…**
>
> Mientras que en el texto de Robson los términos «control» y «contramedida» se usan como sinónimos, algunos autores y apuntes de cátedra hacen una distinción según el momento en que actúan: llaman **controles** a las medidas implementadas *antes* de un incidente para prevenirlo o detectarlo tempranamente (1.ª y 2.ª línea de defensa), y **contramedidas** a las medidas tomadas *después* de ocurrido un incidente para mitigar los daños y recuperar la normalidad (3.ª línea de defensa). Las líneas de defensa las veremos más adelante.

Controles: **prevención y detección**. Son medidas implementadas antes de un incidente para reducir la probabilidad de que ocurra o para detectarlo tempranamente.

Contramedidas: respuesta y mitigación. Son **medidas tomadas después de un incidente para limitar los daños** y recuperar la normalidad.

Los controles y las contramedidas no forman un único conjunto homogéneo. Para lograr una «buena» seguridad, las diversas amenazas deben combatirse con **capas de controles** dirigidos a diferentes aspectos del uso y el management de los IS.

En el caso de los IS, la naturaleza precisa de las instancias de cada capa de control dependerá de:

- **La plataforma de hardware**: influye en el tipo y la cantidad de controles disponibles.
- **El grado de distribución**: influye en el énfasis de los controles.
- **La integración de la infraestructura**: influye en la naturaleza de la amenaza.

Cualquier cambio en este entorno de los IS significa que las consecuencias de seguridad se extienden por todas las capas de control. Aun dentro de cada capa existen diferentes intenciones o etapas de control:

Línea de defensa	Etapa	Descripción
Primera línea de defensa	**Prevención**	Prevenir las amenazas, evitar que ocurran. Por ejemplo: prohibir que se fume en el centro de datos.
Segunda línea de defensa	**Detección**	Detectar fallas de seguridad a pesar de la primera línea de defensa. Por ejemplo: un detector de humo. «Si falla la primera línea, es decir, si ocurre el ataque, debo detectarlo».
Tercera línea de defensa	**Recuperación**	Recuperarse de una falla de seguridad con pérdidas mínimas. Por ejemplo: *backups* de datos. «Volver al estado anterior a la amenaza».

> Estas tres etapas se aplican a la mayoría de las capas de control. Por ejemplo, el software de autorización puede tratar de prevenir el uso no autorizado, pero también registra los ingresos fallidos a fin de detectar los ataques y luego utiliza la encriptación de la segunda etapa para minimizar el daño causado por la entrada ilegal al sistema.

Las herramientas de seguridad son una de las contramedidas que se pueden implementar; también existen las políticas de seguridad y las buenas prácticas de seguridad.

El **principal objetivo** al seleccionar controles y contramedidas —y, por lo tanto, al definir la política de seguridad— es **crear una situación equilibrada entre los costos del riesgo y los costos del control**.

Las contramedidas seleccionadas pueden ser lógicas o físicas:

- Los **controles lógicos** son las medidas adoptadas para asegurar que el desarrollo, la integridad de los datos y las operaciones continúen sin tropiezos. Una de las medidas de control lógico más comunes —y a menudo inadecuada— es el sistema de identificación de usuarios y contraseñas para restringir el acceso a los sistemas.
- Las **medidas físicas** de seguridad generan más costos, son menos efectivas y más propensas a producir resentimiento; por lo tanto, su uso debe evaluarse cuidadosamente. Pueden incluir personal de seguridad, sistemas de vigilancia, cerraduras, tarjetas con clave y otros métodos de acceso. Estas medidas filtran el acceso físico a los elementos de los IS.

Ejemplos de controles:

- Estándares de operatividad.
- División de responsabilidades.
- Medidas de seguridad de la red.
- Contraseñas.
- Encriptación de datos.
- Antivirus.
- Detección y prevención de incendios.

3.1.4. Recuperación ante el desastre

Este elemento asume que la prevención total del riesgo es poco práctica o imposible y que, por lo tanto, la empresa debe definir planes que le permitan sobrevivir a algún tipo de desastre, así como los procesos que permitan la recuperación. Esto se denomina **planificación de contingencias e incluye planes de métodos de trabajo que permitan que la empresa sobreviva al desastre**, y procesos a largo plazo para que la organización se recupere:

- En la primera etapa se busca incrementar la seguridad, minimizar los daños y facilitar el regreso al trabajo.
- En la segunda etapa se minimizan los efectos secundarios del desastre.

Los términos relacionados con estas etapas son:

- **Tiempo de inhabilitación**: cantidad de tiempo que transcurre antes de que los sistemas vuelvan a estar disponibles para las operaciones.
- **Respaldo**: mantener el funcionamiento de la empresa mediante los sistemas clave (críticos y vitales) hasta que se vuelva a la normalidad.
- **Reinstalación**: actualización de los sistemas con todos los datos generados durante el tiempo de inactividad de la sede central.

Por supuesto, el management del riesgo busca prevenir siempre que sea posible, pero también debe prepararse para los desastres. La recuperación ante desastres debe poder llevarse a cabo con rapidez, para estar listos ante cualquier falla en la prevención del riesgo; de hecho, una estrategia de reducción del riesgo reconoce que existe una probabilidad residual de falla de seguridad. **En algunos casos, cuando las consecuencias del riesgo son bajas, la prevención no es mejor que la cura y, entonces, la recuperación en sí misma puede ser una estrategia adecuada de manejo del riesgo.**

El primer paso de la planificación de contingencias consiste en clasificar los sistemas y las aplicaciones según la necesidad de las operaciones empresariales (***grado de tolerancia***). Esta clasificación permite establecer prioridades entre los elementos de los IS. El plan de recuperación debe cubrir todos los aspectos del uso y del management de los SI.

	CRÍTICOS	VITALES	SENSIBLES	NO CRÍTICOS
Tolerancia a la interrupción	Muy baja (Costo de interrupción muy alto)	Moderada (Costo de interrupción ligeramente menor)	Flexible (costos tolerables)	Amplia (Costo escaso o costo adicional nulo)
Reemplazo de funciones	No pueden ser reemplazadas por métodos manuales	Puede ejecutarse manualmente por períodos breves	Pueden realizarse en forma manual por períodos relativamente largos. Exige mano de obra adicional	Pueden reemplazarse con poco esfuerzo

Las organizaciones con un alto nivel de automatización están sometidas a mayores riesgos que las escasamente mecanizadas: tendrán mayores dificultades para restaurar sus procedimientos y, además, menor capacidad para procesar sus datos.

Como la planificación de contingencias forma parte del management estratégico de los SI, no puede separarse de los demás aspectos de la gestión del uso de los SI y debe considerarse junto con otros temas de selección e implementación de estrategias.

Existen dos problemas importantes en la planificación ante desastres: la dificultad de mantenerse actualizado respecto de los tiempos de desastre y la dificultad de mantener actualizados los cronogramas de prioridades.

Se deben tener *backups* y mantenerlos *off-site* (fuera de la sede), para evitar que los posibles desastres los afecten.

Las soluciones de respaldo (mantenimiento) pueden clasificarse en (disponibilidad de hardware alternativo en Lardent):

- **Instalaciones de emergencia**: todo lo que posibilita el funcionamiento de los IS ya está instalado; permiten una operatividad inmediata, siempre que los *backups* de datos estén disponibles.
- **Instalaciones intermedias**: se dispone de un centro de datos vacío, pero equipado. Son menos costosas que las anteriores, pero su puesta en marcha es más lenta.
- **Instalaciones móviles**: la provisión se realiza desde vehículos o desde edificaciones prefabricadas semimóviles.

Todos los enfoques de desarrollo de los SI deben ofrecer puntos de recuperación.

3.1.4.1. Evaluación de riesgos

Los riesgos que interesan en este ámbito son los vinculados con la probabilidad de que se presente un desastre. Un **desastre** es todo suceso sujeto a cierto grado de incertidumbre en cuanto a su ocurrencia, pero que, cuando ocurre, puede interrumpir o afectar seriamente la operación normal de un negocio.

Los riesgos deben clasificarse para priorizar las acciones según la sensibilidad al tiempo (el tiempo necesario para que se reanude el negocio después de un desastre). La evaluación del riesgo debe considerar la tolerancia del sistema, es decir, su capacidad para enfrentar una interrupción. La tolerancia puede expresarse como un valor monetario.

3.1.4.2. Formulación de un Plan de Contingencias

Consiste en definir los planes que permitan a la empresa sobrevivir a algún tipo de desastre y los procesos que permitan la recuperación. Se debe prever: el tiempo de inhabilitación, el respaldo o mantenimiento, la reinstalación y la tolerancia del sistema.

Se pueden diferenciar tres tipos de situaciones de interrupción de las actividades:

1. **Catástrofe**: interrupciones en la capacidad de procesamiento provocadas por la **destrucción de las instalaciones y de los componentes físicos que las integran**. En estos casos se requiere acudir transitoriamente a otra instalación alternativa, de configuración similar a la destruida. Simultáneamente, debe equiparse una nueva instalación que, a muy corto plazo, tenga capacidad de procesamiento continuo del servicio de procesamiento de datos.
2. **Desastre**: **interrupciones en la capacidad de procesamiento de información durante un periodo superior a un día**, pero con altas posibilidades de reanudarlo en la instalación original una vez superados los inconvenientes que causaron la interrupción. Se deberá recurrir a una instalación de procesamiento alternativa, utilizando copias del software y de los archivos de datos conservadas fuera de la sede original.
3. **No desastres**: **interrupciones breves, que no duran más de un día**. Son provocadas por el mal funcionamiento de algún dispositivo o por fallas del software no detectadas anteriormente, que requieren corrección inmediata.

Todo sistema tiene un **lapso crítico de recuperación**: el periodo hasta el que puede extenderse una interrupción antes de que se presente el riesgo de incurrir en pérdidas. La naturaleza del negocio y de los sistemas es lo que condiciona este lapso crítico.

La formulación del plan de contingencias es responsabilidad de la gerencia superior. El plan de contingencias contendrá lo siguiente:

- Determinación del orden de prioridades para la recuperación de aplicaciones, software de base y archivos de datos, según el grado de tolerancia.
- Detalle del orden de procesamiento de las tareas complejas.
- Mecanismos de acoplamiento manual durante interrupciones cortas.
- Consideración de los equipos de todo el ambiente informático, y no solo de las unidades centrales. El personal debe estar entrenado. Sedes remotas.

- Disponibilidad de hardware alternativo, para lo cual hay dos alternativas:
  - Un centro de procesamiento de información duplicado, propiedad de la misma empresa (para aplicaciones críticas). Es eficaz, pero costoso.
  - Centros de procesamiento ubicados en otra sede (mediante contratos con terceros). Según el tiempo de activación y los costos, se clasifican en:
    * ***Hot sites***: son instalaciones completas, configuradas de manera similar a la sede primaria, que pueden activarse rápidamente.
    * ***Warm sites***: son instalaciones parcialmente configuradas, en las que generalmente falta la unidad central de procesamiento. Dado que esta unidad es el dispositivo más costoso, esta alternativa es más económica.
    * ***Cold sites***: son lugares físicos en condiciones de recibir el equipamiento necesario, pero que no disponen de instalaciones específicas.
- Disponibilidad de la capacidad de telecomunicaciones:
  - **Rutas alternativas**: se utilizan cuando se interrumpe la red normal.
  - **Rutas diversificadas**: alternativas ubicadas en un lugar físico distinto.
- Disponibilidad de una sede alternativa para el almacenamiento de los medios magnéticos (datos de *backup*) y de la documentación.

3.1.4.3. Metodologías de recuperación

Establecen los pasos que se deben seguir en las situaciones de emergencia:

- Protección de la vida humana.
- Evaluación de los daños y estimación del tiempo necesario para la recuperación.
- Coordinación de las actividades de recuperación: recuperar los datos vitales y críticos, reconstruir la base de datos, e instalar y probar el software en una sede alternativa.
- Restauración del software de base y de aplicación en la sede alternativa.
- Recuperación de la red de telecomunicaciones.
- Preparación de datos y registro: supervisar la obtención de los datos fuente, su carga y la actualización de la base de datos.
- Almacenamiento en sede alternativa: formular un cronograma y vigilar el cumplimiento de las actividades que se desarrollarán en la sede alternativa para almacenar la información inicial y la que se vaya generando durante el proceso de recuperación.
- Administración de las condiciones de seguridad.
- Provisión de apoyo administrativo, tareas de control y balanceo de datos.
- Gestión de los aspectos legales derivados de la emergencia.

3.1.4.4. Técnicas de auditoría y funciones del auditor en la continuidad de las operaciones

La revisión de la continuidad de las operaciones exige que el auditor de SI ejecute las siguientes tareas:

- Evaluar el plan de contingencias: verificar su adecuación, su actualización y su capacidad para permitir reiniciar el procesamiento de información después de una interrupción imprevista; verificar que considere desastres de diverso grado y que para cada aplicación se haya determinado su nivel de tolerancia.
- Examinar el inventario detallado de los elementos almacenados en la sede alternativa.
- Evaluar el grado de capacitación del personal para enfrentar con éxito la aplicación del plan de contingencias.
- Verificar que el plan contemple mecanismos para fusionar los datos obtenidos o procesados durante el periodo de emergencia con los existentes antes del desastre.
- Evaluar las condiciones de seguridad física de la instalación alternativa en cuanto a controles de acceso.
- Examinar el contrato de procesamiento alternativo con el proveedor de la instalación.
- Evaluar los resultados de pruebas anteriores.
- Analizar la cobertura de seguros.

3.2. Política de seguridad

> Apunte de la profesora.

*«Una **política de seguridad** es el conjunto de requisitos establecidos por los responsables directos o indirectos de un sistema que indica, en términos generales, qué está permitido y qué no está permitido hacer en materia de seguridad durante la operación de dicho sistema».*

> ***Son medidas preventivas. Hay dos niveles: políticas generales, que luego se pueden especificar para cada activo y para cada perfil de usuario. Se usan en la primera línea de defensa.***

Ejemplo de política: los empleados de atención al cliente no pueden cambiar los estados; quien lo hace es el jefe de sección.

Hay dos amplitudes de políticas:

- **Políticas generales.**
- **Políticas específicas**: para cada activo, para cada situación, para cada perfil de usuario.

Al tratarse de «términos generales» aplicables a situaciones y recursos diversos, suele ser necesario refinar los requisitos de la política para convertirlos en indicaciones precisas de qué está permitido y qué está denegado en cierta parte de la operación del sistema. Esto se **denomina política de aplicación específica**. Funcionarían como reglas.

> Ejemplo: el personal de atención al cliente no puede cambiar el estado de un cliente.

> **¿Cómo se clasifican las políticas de seguridad? ¿Cuáles son sus tipos?**

Una política puede ser:

- **Prohibitiva**: todo lo que no está expresamente permitido está denegado.
  - Es mucho más restrictiva, y podría considerarse más efectiva en cuanto a seguridad.

> Ejemplo: al área de TIC solo puede entrar el personal del área; a tal área solo pueden entrar tales personas.

- **Permisiva**: todo lo que no está expresamente prohibido está permitido.

> ***Ejemplo: no puedo tomar mate en el laboratorio, pero entonces sí puedo tomar café o gaseosa.***

Las políticas prohibitivas son más efectivas en cuanto a seguridad.

Cualquier política debe contemplar seis elementos clave de la seguridad de un sistema informático:

- **Disponibilidad**: es necesario garantizar que los recursos del sistema estén disponibles cuando se necesiten, especialmente la información crítica.
- **Utilidad**: los recursos del sistema y la información que se maneja en él deben ser útiles para alguna función.
- **Integridad**: la información del sistema debe estar disponible tal como la almacenó un agente autorizado.
- **Autenticidad**: el sistema debe ser capaz de verificar la identidad de sus usuarios, y los usuarios, la del sistema.
- **Confidencialidad**: la información solo debe estar disponible para agentes autorizados, especialmente para su propietario.
- **Posesión**: los propietarios de un sistema deben ser capaces de controlarlo en todo momento; perder este control en favor de un usuario malicioso compromete la seguridad del sistema frente al resto de los usuarios.

> Esas seis características son los objetivos de protección que justifican la existencia de una política de seguridad. Mientras que la política es el conjunto de reglas que indica qué está permitido y qué está prohibido hacer en el sistema, estos seis elementos definen qué es exactamente lo que esas reglas buscan garantizar y proteger.

3.2.1. Definición de política

Política: declaración general de principios que presenta la posición de la administración para un área de control definida. Las políticas se elaboran para que tengan aplicación a largo plazo y guíen el desarrollo de reglas y criterios más específicos que aborden situaciones concretas. Se despliegan y se sustentan mediante estándares, mejores prácticas, procedimientos y guías. Las políticas deben ser pocas (es decir, un número reducido), deben estar apoyadas y aprobadas por las autoridades de la universidad y deben ofrecer lineamientos a toda la organización o a un conjunto importante de dependencias. Por definición, las políticas son obligatorias, y la imposibilidad de cumplir una política exige que se apruebe una excepción.

Estándar: regla que especifica una acción o respuesta que se debe seguir ante una situación dada. Los estándares son orientaciones obligatorias que buscan hacer cumplir las políticas. Sirven como especificaciones para implementarlas: están diseñados para promover la implementación de las políticas de alto nivel de la organización, antes que para crear nuevas políticas.

Mejor práctica: regla de seguridad específica de una plataforma, aceptada en la industria por proporcionar el enfoque más efectivo para una implementación de seguridad concreta. Las mejores prácticas se establecen para asegurar que las características de seguridad de los sistemas utilizados con regularidad estén configuradas y administradas de manera uniforme, lo que garantiza un nivel de seguridad consistente en toda la organización.

Guía: declaración general utilizada para recomendar o sugerir un enfoque para implementar políticas, estándares y buenas prácticas. Las guías son, esencialmente, recomendaciones que deben considerarse al implementar la seguridad. Aunque no son obligatorias, se seguirán a menos que existan argumentos documentados y aprobados para no hacerlo.

Procedimiento: los procedimientos definen específicamente cómo se implementarán las políticas, los estándares, las mejores prácticas y las guías en una situación dada. Dependen de la tecnología o de los procesos, y se refieren a plataformas, aplicaciones o procesos específicos. Se utilizan para delinear los pasos que debe seguir una dependencia para implementar la seguridad relacionada con dicho proceso o sistema específico. Generalmente, los desarrolla, implementa y supervisa el dueño del proceso o del sistema. Los procedimientos seguirán lo más fielmente posible las políticas, los estándares, las mejores prácticas y las guías de la organización y, a la vez, se ajustarán a los requerimientos procedimentales o técnicos establecidos dentro de la dependencia en la que se aplican.

Ejemplo:

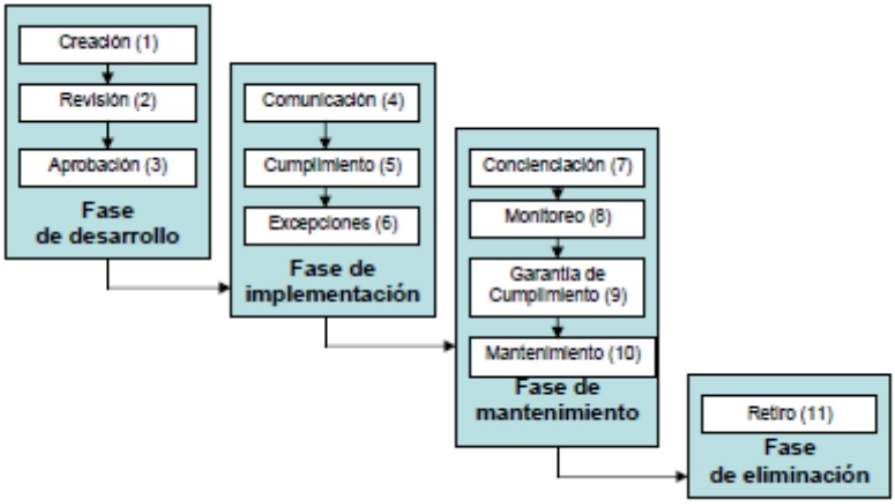
- En el nivel más alto, se puede elaborar una **política** para toda la organización que obligue a «garantizar la seguridad del correo electrónico cuyo contenido sea información confidencial».
- Esta política podría sustentarse en varios **estándares**; por ejemplo, que los mensajes de este tipo se envíen mediante algún sistema de criptografía aprobado por la universidad y que se borren de manera segura después de su envío.
- Una **mejor práctica**, en este ejemplo, podría referirse a la manera de configurar el correo en un tipo específico de sistema (Windows o Linux) para garantizar el cumplimiento de la política y del estándar.

- Los **procedimientos** podrían especificar los requerimientos para que la política y los estándares que la sustentan se apliquen en una dependencia específica; por ejemplo, la Oficina de Control Interno.
- Finalmente, las **guías** podrían incluir información sobre técnicas, configuraciones y secuencias de comandos recomendadas que deben seguir los usuarios para proteger la información confidencial enviada y recibida a través del servicio de correo electrónico.

3.2.2. Ciclo de vida de una política

1. **Fase de desarrollo**:
    1. **Creación**: se planifica, investiga y redacta la política. Implica identificar su necesidad y determinar su alcance y su aplicabilidad.
    2. **Revisión**: una vez documentada, la política se remite a un grupo o a una persona para que la revise de forma independiente antes de la aprobación final.
    3. **Aprobación**: se debe obtener el apoyo de la administración. La aprobación permite iniciar la implementación de la política.
2. **Fase de implementación**:
    1. **Comunicación**: consiste en difundir la política y concientizar sobre ella a los miembros de la organización.
    2. **Cumplimiento**: se debe hacer un seguimiento de su cumplimiento.
    3. **Excepciones**: debido a problemas de gestión, no todas las políticas pueden cumplirse de la forma planteada inicialmente. Por eso, a veces existen excepciones, que deben documentarse.
3. **Fase de mantenimiento**:
    1. **Concientización**: busca que las personas cumplan la política y entiendan su importancia en la estructura organizativa. Es un trabajo continuo.
    2. **Monitoreo**: consiste en realizar un seguimiento de la efectividad de la política e informar sobre ella.
    3. **Garantía de cumplimiento**: identifica los incumplimientos de la política para, después de analizar sus causas, intentar evitar que se repitan.
    4. **Mantenimiento**: la política es contingente.

    > Decir que la política es “contingente” significa que no es estática ni definitiva, sino que depende de las circunstancias del entorno y está sujeta a cambios continuos.
4. **Fase de eliminación**:
    1. **Retiro**: una vez que la política cumplió su finalidad y ya no es necesaria (por ejemplo, por grandes avances tecnológicos), debe retirarse.



3.3. Clasificación y tipos de ataques contra sistemas de información

Se denomina **delito informático a toda acción culpable realizada por un ser humano que cause perjuicio a otras personas** —sin que necesariamente se beneficie el autor— o que, por el contrario, produzca un beneficio ilícito a su autor **aunque no perjudique de forma directa o indirecta a la víctima; está tipificada por la ley, se realiza en un entorno informático y está sancionada con una pena**.

Un ataque no es más que la realización de una amenaza. Las cuatro categorías generales de amenazas o ataques son las siguientes:

- **Interrupción**: un recurso del sistema es destruido o deja de estar disponible. Es un ataque contra la **disponibilidad**. Ejemplos: la destrucción de un elemento de hardware, como un disco duro; el corte de una línea de comunicación, o la inhabilitación del sistema de gestión de ficheros.
- **Intercepción**: una entidad no autorizada consigue acceder a un recurso. Es un ataque contra la **confidencialidad**. La entidad no autorizada podría ser una persona, un programa o un ordenador. Ejemplos: pinchar una línea para hacerse con los datos que circulan por la red, la copia ilícita de ficheros o programas (intercepción de datos), o la lectura de las cabeceras de los paquetes para desvelar la identidad de uno o más de los usuarios implicados en la comunicación observada ilegalmente (intercepción de identidad).
- **Modificación**: una entidad no autorizada no solo consigue acceder a un recurso, sino que es capaz de manipularlo. Es un ataque contra la **integridad**. Ejemplos: el cambio de valores en un archivo de datos, la alteración de un programa para que funcione de forma diferente o la modificación del contenido de los mensajes que se transfieren por la red.
- **Fabricación**: una entidad no autorizada inserta objetos falsificados en el sistema. Es un ataque contra la **autenticidad**. Ejemplos: la inserción de mensajes espurios en una red o el agregado de registros a un archivo.

Estos ataques también pueden clasificarse, de forma útil, en ataques pasivos y ataques activos:

- **Ataques pasivos**: el atacante no altera la comunicación, sino que únicamente la escucha o monitoriza para obtener la información que se transmite. Sus objetivos son la intercepción de datos y el análisis de tráfico. Son muy difíciles de detectar, ya que no provocan ninguna alteración de los datos. Sin embargo, es posible evitar su éxito mediante el cifrado de la información y otros mecanismos.
- **Ataques activos**: implican algún tipo de modificación del flujo de datos transmitido o la creación de un flujo de datos falso. Pueden subdividirse en cuatro categorías:
  - **Suplantación de identidad**: el intruso se hace pasar por una entidad diferente. Normalmente incluye alguna de las otras formas de ataque activo. Por ejemplo, las secuencias de autenticación pueden capturarse y repetirse, lo que permite a una entidad no autorizada acceder a una serie de recursos privilegiados suplantando a la entidad que posee esos privilegios, como al robar la contraseña de acceso a una cuenta.
  - **Reactuación**: uno o varios mensajes legítimos se capturan y se repiten para producir un efecto no deseado; por ejemplo, ingresar dinero repetidas veces en una cuenta dada.
  - **Modificación de mensajes**: se altera una porción del mensaje legítimo, o los mensajes se retardan o se reordenan, para producir un efecto no autorizado. Por ejemplo, el mensaje «Ingresa un millón de pesos en la cuenta A» podría modificarse para que diga «Ingresa un millón de pesos en la cuenta B».
  - **Degradación fraudulenta del servicio**: impide o inhibe el uso normal o la gestión de los recursos informáticos y de comunicaciones. Por ejemplo, el intruso podría suprimir todos los mensajes dirigidos a una determinada entidad o interrumpir el servicio de una red inundándola con mensajes espurios.

4. Auditoría

Videos

Se trata de una actividad que consiste en:

- **Contenido**: una opinión.
- **Condición**: profesional.
- **Justificación**: sustentada en determinados procedimientos.
- **Objeto**: una determinada información obtenida en cierto soporte. Es un informe.
- **Finalidad**: determinar si esa información presenta adecuadamente la realidad o si responde a las expectativas (objetivos de funcionamiento, de rendimiento) que se le atribuyen, es decir, su fiabilidad.

> **Nota...**
>
> **Definición general**: es la emisión de una opinión **profesional** y **fundamentada** (en procedimientos preestablecidos) sobre una información concreta recogida en un determinado soporte, plasmada en un **informe** cuyo fin es determinar si dicha información **presenta adecuadamente la realidad** o si responde a las expectativas (objetivos de funcionamiento, rendimiento, fiabilidad) que se le atribuyen.

Por ejemplo: un auditor contable opina que el sistema contable auditado tiene un comportamiento aceptable, o inaceptable, de acuerdo con determinados criterios (normas, estándares, leyes, etc.).

Hay distintos tipos de auditoría según su **naturaleza**:

- **Financiera**: evalúa la exactitud de los registros y de los estados contables.
- **Administrativa.**
- **De gestión de RR. HH.**: evalúa los procedimientos de RR. HH., los procedimientos de remuneración variable, etc.
- **De calidad.**
- **Operativa**: evalúa la estructura de control interno en un área determinada; mide y evalúa la eficacia de otros controles.
- **De sistemas de información.**

Una auditoría global involucra tanto la auditoría contable como la auditoría operativa. La auditoría de sistemas forma parte de la auditoría global.

La auditoría general involucra una auditoría externa y una interna. Durante su planificación debería establecerse una relación entre la actividad de los auditores externos y la de los internos. De esta forma se evitan duplicaciones inútiles de esfuerzos y el desperdicio de recursos, y la coordinación de ambos grupos permite alcanzar una cobertura de auditoría más completa. **Si los controles y los procedimientos son buenos, se hará hincapié en las pruebas de cumplimiento. Si, por el contrario, los controles son débiles o inexistentes, se harán más pruebas sustantivas.**

> **Pruebas de cumplimiento (revisan "las reglas y el proceso"):** Buscan comprobar si los controles y procedimientos definidos en los manuales y políticas realmente se cumplen en el día a día de manera consistente y continua. Su insumo principal es la documentación, la observación y las entrevistas.
> **Pruebas sustantivas o de validación (revisan "los datos y los resultados a fondo"):** Van directamente al tratamiento de la información dentro del sistema para comprobar si los datos fueron corrompidos, alterados o si hubo fraudes o errores (como transacciones omitidas, duplicadas o cálculos mal hechos).

4.1. Auditoría de sistemas/informática (Lardent)

La auditoría de sistemas de información ha sido definida como la revisión sistemática y organizada de los sistemas en funcionamiento para ver si verifican las propiedades de:

- **Vigencia de los objetivos planteados como base del diseño original** (entendiendo por diseño el arreglo o la coordinación de las partes o detalles del sistema).
- **Concordancia del sistema con los objetivos (efectividad).** Básicamente, si está cumpliendo el objetivo.
- **Permanencia del diseño por no haber sufrido alteraciones que lo degradaran operativamente.** Por ejemplo, que la lógica no esté alterada.
- **Eficiencia del sistema (relación costo-beneficio).**
- **Seguridad del sistema.**

Finalidad: ***evaluar si la operatividad de los sistemas se realiza en forma efectiva (fiable) y segura, según las normas establecidas*** (por ejemplo, para asegurar el cumplimiento de alguna norma del Banco Central). La información se usa para la toma de decisiones y, por ello, debe ser certera.

Respecto de los sistemas, la auditoría de sistemas debe asegurar lo siguiente:

- La existencia de pistas de auditoría (trazabilidad, para que las operaciones puedan rastrearse).
- La existencia de controles adecuados sobre la entrada de datos y el mantenimiento de su integridad, así como sobre las transacciones que se efectúan con ellos a través del segmento computarizado del sistema.
- El manejo adecuado de las excepciones y de los rechazos originados por los controles de entrada de datos, y el aseguramiento de su incorporación al sistema en los casos que corresponda.
- El aseguramiento de las políticas corporativas y el cumplimiento de los reglamentos gubernamentales que se hayan incorporado.
- La verificación de que los sistemas se comporten según fueron definidos.
- El aseguramiento de la adecuada interconexión de los sistemas.
- El control de que las modificaciones que se realicen sobre los sistemas estén debidamente autorizadas por el nivel jerárquico que corresponda.
- La existencia de condiciones y procedimientos de seguridad que protejan los datos de la organización.

Objeto de audito: recursos informáticos (servidores, computadoras), función de SI (como unidad organizativa: la gerencia de sistemas), aplicaciones, proyectos, planes de contingencia, almacenamientos de datos, etc.

4.1.1. Aspectos a revisar por la auditoría de sistemas (áreas)

- Revisión de los controles generales que afectan la estructura de la organización, las políticas y procedimientos, y el ambiente de control de los sistemas de información.
- Revisión de las operaciones de procesamiento de información en el ambiente informático.
- Revisión de la seguridad en cuanto a la calidad del acceso lógico y físico, y de los controles existentes en el ambiente informático.

- Revisión del software del sistema operativo.
- Revisión de la metodología de desarrollo de sistemas de información.
- Revisión de los controles del software de aplicación.
- Plan de contingencias: que exista y que sea coherente con los objetivos propuestos.

La Auditoría Informática es el proceso de recolección y evaluación de evidencias para determinar cuándo se salvaguardan los activos de los sistemas computarizados, de qué manera se mantiene la integridad de los datos, y cómo se logran eficazmente los objetivos de la organización y se usan eficientemente los recursos consumidos. La Auditoría Informática sigue los objetivos tradicionales de la auditoría: los de la auditoría externa (salvaguarda de los activos e integridad de los datos) y los objetivos gerenciales, propios de la auditoría interna, que abarcan no solo los objetivos señalados, sino también los de eficiencia y eficacia.

La Auditoría Informática tiene **como objetivo evaluar periódicamente la eficacia, la eficiencia y la integridad de los sistemas de información mediante la recolección y el análisis de evidencias y la evaluación de los controles internos implementados, con el fin de verificar si estos salvaguardan los activos, aseguran la integridad de los datos, garantizan el cumplimiento de los objetivos organizacionales y permiten un uso eficiente de los recursos**.

4.2. Control interno

El control interno puede definirse como *cualquier actividad o acción, realizada manual o automáticamente, para prevenir o corregir errores o irregularidades que puedan afectar el funcionamiento de un sistema para cumplir sus objetivos.* Se asemeja a las líneas de defensa.

4.2.1. Categorías de controles (Lardent)

1. **Preventivos**: diseñados para evitar que se produzca un error, una omisión o un acto malicioso. Ejemplo: un control de acceso lógico que solo permite a personas autorizadas, y desde lugares autorizados, acceder a archivos de información sensible.
2. **Correctivos**: corrigen errores, omisiones o actos maliciosos. Ejemplo: un campo de fecha que corrige el formato ingresado, o la recuperación de un archivo dañado a partir de las copias de seguridad. Buscan restablecer el funcionamiento de los sistemas si ocurrió algún daño.
3. **De Detección**: detectan que se ha producido un error, una omisión o un acto malicioso, e informan de su aparición. Actúan cuando fallan los preventivos. Ejemplo: un software de seguridad de acceso que registra los intentos de acceso no autorizado.

4.2.2. Implantación de un Sistema de Control Informático Interno (Piattini)

Los controles pueden implantarse en varios niveles diferentes; por ello, es importante conocer bien la configuración del sistema (el entorno). Para conocerla es necesario documentar los detalles de la red, así como los distintos niveles de control y los elementos relacionados:

- Entorno de red.
- Configuración del ordenador base.
- Entorno de aplicaciones.
- Productos y herramientas ⟶ decidir qué herramienta se implementa es una medida de control interno.
- Seguridad del ordenador base.

Para implantar un sistema de controles internos informáticos, primero hay que conocer la configuración del ambiente informático y luego definir:

- **Gestión de sistemas de información**: políticas, pautas y normas técnicas que sirvan de base para el diseño y la implantación de los sistemas de información y de los controles correspondientes.
- **Administración de sistemas**: controles sobre la actividad de los centros de datos y otras funciones de apoyo al sistema, incluida la administración de las redes.
- **Seguridad**: incluye las tres clases de controles fundamentales implantados en el software del sistema: integridad del sistema, confidencialidad (control de acceso) y disponibilidad.
- **Gestión del cambio**: separación entre pruebas y producción a nivel de software, y controles de procedimientos para la migración de programas de software aprobados y probados. Brinda garantías de que el diseño original del sistema se mantiene y de que los cambios no lo afectan en su esencia. La medida de control interno es cómo se van autorizando los cambios.

La implantación de una política y una cultura de seguridad debe realizarse por fases y estar respaldada por la Dirección. Cada función cumple un papel importante en las distintas etapas:

- **Dirección de Sistemas de Información (SI)**: debe definir la política o las directrices para los sistemas de información según las exigencias del negocio, que podrán ser internas o externas.
- **Dirección de Informática**: debe definir las normas de funcionamiento del entorno informático y de cada una de las funciones de Informática mediante la creación y publicación de procedimientos, estándares, metodologías y normas aplicables a todas las áreas de Informática.
- **Control Interno Informático**: define los controles periódicos que deben realizarse en cada una de las funciones informáticas.
- **Auditor interno/externo informático**: debe revisar los diferentes controles internos definidos en cada una de las funciones informáticas y el cumplimiento de la normativa interna y externa.

La creación de un sistema de control informático es una responsabilidad de la Gerencia y un punto destacable de la política del entorno informático.



4.2.3. Auditoría informática vs. Control Interno Informático (Piattini)

La auditoría informática:

- Tiene una función de vigilancia y evaluación mediante dictámenes, y todas sus metodologías se orientan a esta función.
- Tiene objetivos propios, distintos de los de los auditores de cuentas, aunque necesarios para que estos puedan utilizar la información de sus sistemas en sus evaluaciones financieras y operativas. Evalúa la eficiencia, el costo y la seguridad en su visión amplia, es decir, todos los riesgos informáticos: los clásicos (confidencialidad, integridad y disponibilidad), los de costos y los jurídicos, dado que en la mayoría de los casos ya no hay una separación clara.
- Opera según el plan auditor.
- Utiliza metodologías de evaluación de tipo cualitativo, con la característica de las pruebas de auditoría.
- Establece planes quinquenales como ciclos completos.
- Cuenta con sistemas de evaluación de la repetición de la auditoría según el nivel de exposición del área auditada y el resultado de la última auditoría de esa área.
- Puede cumplir (opcionalmente) la función de soporte informático de todos los auditores, aunque debe quedar claro que la auditoría informática no consiste solo en esto.

Control Interno Informático:

- Tiene funciones propias (administración de la seguridad lógica, etc.).
- Cumple funciones de control dual con otros departamentos.
- Cumple una función normativa y de cumplimiento del marco jurídico.
- Opera según procedimientos de control en los que está involucrado y que luego se desarrollarán.
- Al igual que la auditoría, y de forma opcional, puede ser el soporte informático del control interno no informático.

> **Nota...**
>
> El Control Interno vive en el «día a día», monitorizando y ajustando los controles.
>
> La Auditoría Informática llega después, toma muestras y emite un dictamen sobre si todo funcionó según lo planificado.

4.3. Control interno informático (Piattini)

Como unidad organizativa: ***es el departamento, la dirección, etc., que se crea para controlar diariamente que todas las actividades de los SI/TI se realicen cumpliendo los procedimientos, estándares y normas fijados por la dirección de la organización o por la dirección informática, así como los requerimientos legales*** (Piattini).

Misión (finalidad): asegurarse de que las medidas implementadas por cada responsable sean correctas y válidas; es decir, de que se estén cumpliendo.

Objetivos (como unidad organizativa):

- Colaborar con las auditorías informáticas, tanto internas como externas. El área les provee el principal insumo.
- Controlar que todas las actividades se efectúen de acuerdo con los procedimientos y normas fijados.
- Asesorar sobre el conocimiento y la aplicación de las normas, así como asesorar y transmitir.
- Intervenir en la definición, implementación y ejecución de mecanismos y controles para comprobar el logro de los niveles de servicio adecuados (no es responsabilidad exclusiva del CII).
- Realizar, sobre los diferentes SI y entornos informáticos, el control de actividades operativas como:
  - Cumplimiento de procedimientos, normas y controles (cambios de versiones de software).
  - Controles sobre la producción diaria.
  - Controles de calidad y eficiencia en el desarrollo y el mantenimiento del software.
  - Controles sobre las redes y el software de base.
  - Controles sobre la seguridad informática.
  - Controles sobre las licencias y las relaciones contractuales de los esquemas de *outsourcing*.

Los controles deben ser, al menos, completos, simples, fiables, revisables, adecuados y rentables. Respecto de esto último, habrá que analizar el costo-riesgo de su implantación.

Para asegurar la integridad, la disponibilidad y la eficacia de los sistemas se requieren mecanismos de control complejos, la mayoría de ellos automáticos.

Por ejemplo: controlar que los operarios de Agunsa no se pasen las contraseñas, o tener un mecanismo que controle que los dispositivos se dejen en el lugar previsto.

4.3.1. Similitudes y diferencias entre control interno informático y auditor informático interno

Similitudes: ambos cuentan con personal especializado en TI y verifican el cumplimiento de los controles internos, la normativa y los procedimientos establecidos por la Dirección de Informática y la Dirección General para los sistemas de información.

Diferencias:

- **Control interno informático**: analiza los controles en el día a día, informa a la dirección del Departamento de Informática, lo realiza solo personal interno y el alcance de sus funciones se limita al Departamento de Informática.
- **Auditor informático**: analiza un momento informático determinado, informa a la dirección general de la organización, puede ser personal interno o externo y tiene cobertura sobre todos los componentes de los SI de la organización.

4.4. Etapas de la auditoría

Las etapas genéricas de la ISACA (*Information Systems Audit and Control Association* o Asociación de Auditoría y Control de Sistemas de Información) son:

1. Planeación.
2. Trabajo de campo y documentación.
3. Reporte y seguimiento.

En la materia no se ve una metodología específica de auditoría, pero es importante tener en cuenta:

1. Identificar el **alcance** (*qué* se va a auditar y qué no; se describen los objetos de audito) y los **objetivos** (*para qué* se hace la auditoría: ¿hay degradaciones?, ¿es una evaluación porque el sistema se implementó hace poco?) de la auditoría informática, es decir, del objeto que se estudiará.
2. Realizar el **estudio inicial** del entorno que se auditará (aquí se deberían identificar los controles clave). Se hace para reducir el riesgo inherente, identificar fuentes, etc.
3. Ejecutar el **programa de revisión** (aquí entra la metodología específica).
4. Cerrar la **revisión**: se reúnen todos los informes y se analizan los hallazgos.
5. Realizar el **informe final**.
6. Hacer el **seguimiento** (de las recomendaciones: verificar si las medidas se adoptaron y qué efectividad tuvieron).

Para determinar el área o la aplicación que se auditará deben establecerse criterios y prioridades que definan el orden en que se auditarán las distintas áreas. Este orden está muy influido por el impacto de las áreas auditadas en el negocio, el nivel de activos controlados por el sistema, la dimensión de la aplicación, su impacto en la toma de decisiones, etc.

4.5. Programa de revisión

El **programa de auditoría** es un conjunto de instrucciones que guía a los auxiliares involucrados en la auditoría y sirve como medio para controlar y registrar la ejecución apropiada del trabajo. Como los programas de auditoría se preparan anticipadamente, en la etapa de planeación, pueden modificarse a medida que se ejecuta el trabajo, según los hechos concretos que se vayan observando.

1. Deriva del plan de auditoría general.
2. Se elabora un programa por cada área de auditoría, es decir, por cada sección que se auditará.
3. Detalla:
    1. **La naturaleza, la oportunidad y el alcance de los procedimientos de auditoría, según el plan general de AI.**
    2. **Una descripción de los objetivos de auditoría.**
    3. **Las fuentes de evidencia.**
    4. **El equipo de auditoría.**
    5. **El programa de trabajo específico: para cada objetivo, las pruebas, actividades, hitos de revisión, presentación de informes parciales, tiempo estimado, tiempo real, la referencia del papel de trabajo donde quedó plasmada la ejecución del programa, la rúbrica de quien realizó cada paso y su fecha.**
        - Condiciones o situaciones que requieran tomar decisiones.

4.6. Pasos para la ejecución de una auditoría de sistemas de información

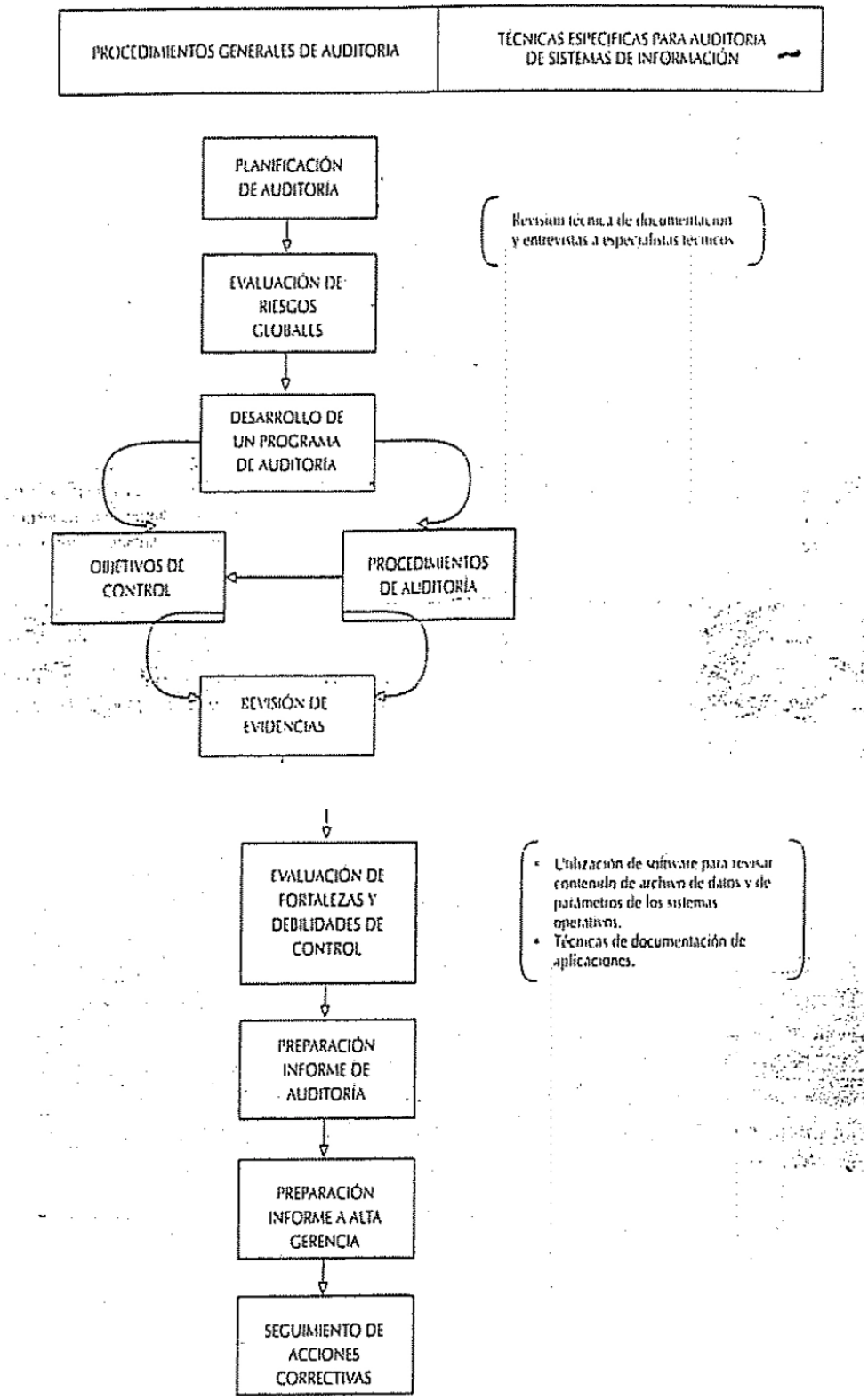


Figura 20-5. Desarrollo de una Auditoría de Sistemas de Información.

Entre los aspectos que el auditor de sistemas de información debe considerar al planificar se encuentran los siguientes:

- **Conocimiento del negocio y su ambiente**: conocer el negocio significa saber qué se va a revisar y sobre qué se va a opinar. El auditor también debe conocer el ambiente normativo en el que opera el negocio. La información sobre el negocio relacionada con el procesamiento de datos se obtiene recorriendo las instalaciones de la organización, entrevistando a los gerentes usuarios de la información y al personal del departamento de sistemas, y leyendo los planes estratégicos a largo plazo y todo el material que reúna antecedentes de la organización.
- **Evidencia de auditoría y auditabilidad**: la actividad de Auditoría de SI debe contar con fuentes verificables de evidencia de auditoría, necesarias para probar los controles o para realizar procedimientos de pruebas de sustanciación.

La planificación de la auditoría incluye:

- **Determinar el área o aplicación que se auditará**: identificar el área que será auditada.
- **Definir el objetivo**: determinar el objetivo o propósito de la auditoría.
- **Establecer el alcance**: identificar los sistemas, aplicaciones o módulos que se revisarán, para acotar la revisión, así como la duración de la auditoría. El auditor no puede auditar todos los sistemas al mismo tiempo, por lo que deben establecerse criterios que faciliten ese ordenamiento.
- **Planear los recursos**: determinar los recursos necesarios para llevar a cabo la auditoría.

4.6.1. Evaluación de riesgos globales

En la auditoría, el **riesgo** se refiere a la posibilidad de que la información contenga errores materiales (significativos en los estados contables) o de que el auditor no detecte errores ocurridos. Los riesgos pueden ser:

- **Riesgo Inherente**: es el riesgo de que se produzca un error material debido a la *propia naturaleza de la actividad*. El auditor no puede controlarlo para eliminarlo. Por ejemplo, puedo hacer una auditoría de la función informática, pero, si la empresa se dedica al desarrollo, quizá no sea el indicado, porque no domino la naturaleza de lo que estoy auditando. Para reducirlo se hace el análisis inicial de la organización.
- **Riesgo de control**: es el riesgo de que un error material no pueda evitarse o detectarse oportunamente debido a *deficiencias en el sistema de control interno*. El auditor no puede controlarlo para eliminarlo, pero sus recomendaciones deben contribuir a reducirlo.
- **Riesgo de detección**: es el riesgo que se corre cuando el auditor realiza *pruebas exitosas a partir de un procedimiento de prueba inadecuado*. Por lo tanto, se puede concluir que no existen errores cuando, en realidad, los hay. Es del ámbito y la tarea exclusiva del auditor.

Estos riesgos también tienen una implicancia material, es decir, económica.

4.6.2. Desarrollo del programa de auditoría

Una vez finalizada la planificación, y antes de ejecutar la auditoría, quedarán definidos el tema y el área que se auditará, el objetivo de la auditoría, su alcance (uno o varios sistemas, o un periodo determinado),

las habilidades técnicas y los recursos necesarios, y las fuentes de información para ejecutar pruebas y revisiones. La figura indica los pasos que deben desarrollarse:



Figura 20-8. Desarrollo del programa de auditoría de sistemas de información.

4.7. La importancia de los procedimientos (Soria Ojeda)

Dentro de la planeación hay que entender la importancia de los procedimientos para garantizar que todo lo que se sigue y lo que fundamenta la opinión sea correcto.

Los procedimientos son el fundamento y, a la vez, la justificación de la opinión profesional, ya que:

- **Proporcionan una seguridad razonable de lo que se afirma** (permiten obtener evidencias y conclusiones). Si hay una receta y se la sigue, razonablemente el resultado saldrá bien; si se cambian sus pasos, ya no.
- **Determinan la trascendencia (el impacto) de la auditoría.**

En cuanto a la ejecución de la auditoría, deben establecerse procedimientos para:

- Planificar y supervisar la auditoría.
- Estudiar y evaluar el control interno.
- Obtener evidencia suficiente y adecuada.

4.8. Evidencia en la auditoría

El concepto de ***evidencia*** **se define como el conjunto de información (todo dato, documento, registro o testimonio) que el auditor ha reunido y del que dispone para determinar si el ente o los datos auditados han cumplido con los criterios u objetivos de auditoría.**

La evidencia debe reunir ciertas condiciones de calidad:

- **Relevante**: tiene una relación lógica con los objetivos de la auditoría.
- **Fiable**: es válida y objetiva, aunque con cierto nivel de confianza.
- **Suficiente**: es de tipo cuantitativo y permite sustentar la opinión profesional del auditor.
- **Adecuada**: es de tipo cualitativo y permite incidir en las conclusiones del auditor.

Se debe considerar la confiabilidad de la evidencia en la que se apoya el auditor:

- **Evidencia de fuentes externas**: la obtenida fuera de la organización. Es más confiable porque, en principio, es objetiva.
- **Objetividad**: es preferible la evidencia objetiva a aquella sobre la que debe emitirse un juicio de valor.
- **Calidad de la fuente de evidencia**: la confiabilidad de la evidencia depende de las características de quien provee la información.

La evidencia se recopila durante el proceso de auditoría y es el fundamento sobre el cual se formulan las conclusiones. **Las pruebas son el método o proceso mediante el cual se obtiene la evidencia**: son las acciones que se realizan para recopilar la información que servirá de base para las conclusiones del auditor. En principio, las pruebas son de cumplimiento o sustantivas.

> **¿Prueba o evidencia?**
>
> Recordá que en auditoría son dos cosas distintas: la prueba es la acción que hacés (el verbo) y la evidencia es el dato o documento que conseguís gracias a esa acción (el sustantivo).

4.9. Tipos de pruebas

La auditoría distingue dos categorías de pruebas: las de cumplimiento y las sustantivas.

1. **Una prueba de cumplimiento** tiene por objeto ***determinar si los controles que se realizan se ajustan a las políticas y procedimientos de la organización, y si se aplican conforme a la descripción de la documentación de los programas de computación***. Su insumo es la documentación. Ejemplo: verificar que el programa en uso sea la misma versión que las versiones fuente y objeto almacenadas en la biblioteca. Se clasifican en:
    1. **Pruebas de detalles: requieren la revisión de documentos. Son más pasivas.**
    2. **Pruebas de observación e indagación: implican tomar acciones para detectar errores. Son más activas. Por ejemplo: indagar al personal, aplicar programas de revisión de archivos, etc.**
2. **Las pruebas sustantivas** intentan ***verificar la adecuación de los controles existentes para proteger a la organización de las actividades fraudulentas. Les importa cómo se procesa la información.*** Indagan haciendo; por ejemplo, mediante el procesamiento en paralelo, para comprobar que los controles implementados (manuales y automatizados) resisten los intentos de alterar la información. ***Aquí se prueban los sistemas***: apuntan al tratamiento de la información y ***garantizan que los sistemas hacen lo que tienen que hacer***. Se usan herramientas informáticas.

4.10. Objetos (secciones de la auditoría de sistemas)

Áreas de la auditoría de SI:

1. Evaluación de la función informática (organización y administración del ambiente informático).
2. Evaluación de los sistemas y procedimientos:
    1. Auditoría del desarrollo de sistemas.
    2. Auditoría de sistemas instalados.
3. Evaluación del proceso de datos, de los sistemas y de los equipos.
4. Evaluación de la seguridad.
5. Evaluación de los aspectos legales de los sistemas y de la información.

4.11. Deontología (reglas éticas) del auditor

Es el conjunto de principios y reglas éticas que regulan y guían una actividad profesional. Estas normas determinan los deberes mínimamente exigibles a los profesionales en el desempeño de su actividad.

- **Principio de beneficio del auditado**: no ir con prejuicios.
- **Principio de independencia**: asegura que el auditor sea objetivo. No puede auditar nada con lo que tenga algún vínculo. Implica independencia de criterio. En la auditoría interna debe garantizarse mediante la estructura organizativa (el auditor deberá depender del gerente) y el auditor no debe estar involucrado en el área de desarrollo.

4.12. Auditoría interna

Según la relación del auditor con la empresa, una auditoría puede ser interna o externa.

Es el examen crítico, sistemático y detallado de un sistema de información de una unidad económica, *realizado por un profesional con vínculos laborales con ella*, utilizando técnicas determinadas, con el objeto de emitir informes y formular sugerencias para su mejoramiento. Estos informes son de **circulación interna.**

> Acá hablamos de «unidad económica» porque es el término técnico-contable más amplio y preciso para referirse a cualquier ente organizado (empresa privada, PYME, banco, organismo estatal o universidad) que administra recursos y activos (incluida la información) para cumplir un fin, y cuyos sistemas informáticos deben ser evaluados por ese auditor externo («sin vínculos laborales con ella»).

La auditoría interna es un servicio que reporta al más alto nivel de la dirección de la organización y tiene características de función asesora de control. Por lo tanto, no puede ni debe tener autoridad de línea sobre ningún funcionario de la empresa, salvo sobre quienes integran la planta de la oficina de auditoría interna, ni debe involucrarse o comprometerse de ningún modo con las operaciones de los sistemas de la empresa.

La tarea de la auditoría interna exige una absoluta ***independencia de criterio por parte del auditor***, que se consigue mediante la **estructura organizacional y la objetividad**:

- La organización debe estar estructurada de manera que la auditoría interna tenga suficiente autoridad para actuar sobre el personal de línea frente a las recomendaciones o los hallazgos del auditor.
- La objetividad se manifiesta en que el auditor no puede involucrarse en el desarrollo y la instalación de procedimientos que luego él mismo deberá evaluar. No obstante, el auditor debe participar en la determinación de los **puntos de control** que deben incorporarse en todo sistema de información.

Objetivo: **descubrir *deficiencias o irregularidades* en alguna de las partes de la empresa examinada y señalar sus posibles soluciones, actuando como auxiliar de la dirección para lograr una administración óptima**.

No puede realizarla personal con cargo de «jefe de línea». Busca ayudar a la gerencia a ejecutar sus funciones con efectividad.

4.13. Auditoría externa

Es el examen crítico, sistemático y detallado de un sistema de información de una unidad económica, realizado por un profesional *sin vínculos laborales con ella*, utilizando técnicas determinadas, con el objeto de emitir una opinión independiente sobre la forma en que opera el sistema y su control interno, y de formular sugerencias para su mejoramiento.

Una auditoría externa se lleva a cabo cuando se tiene la intención de publicar el producto del SI examinado, acompañado de una opinión independiente que le dé autenticidad y permita a los usuarios de esa información tomar decisiones confiando en las declaraciones del auditor.

Reporta a organismos oficiales públicos o a determinadas empresas. *Tiene implicancias legales.* Su periodicidad es puntual. *Está habilitada legalmente para dar fe pública.* Es imprescindible para obtener certificaciones.

Objetivo: ***averiguar la razonabilidad, la integridad y la autenticidad*** **de los estados, expedientes y documentos, y de toda la información producida por los sistemas de la organización.**

4.14. Comparación entre el control interno, auditoría interna y externa informática

Control Interno Informático	Auditoría Interna Informática	Auditoría Externa Informática
Análisis de los controles en el día a día.	Evaluación de un momento informático determinado.	Evaluación independiente y objetiva de los sistemas informáticos, realizada por profesionales externos a la organización con experiencia en auditoría informática, con un enfoque en la independencia y la objetividad.
Informa a la Dirección del Departamento de Informática.	Informa a la Dirección General de la organización.	Alcance: aspectos específicos de la infraestructura informática, como la seguridad, la disponibilidad de los sistemas o el cumplimiento de leyes y regulaciones.
Solo personal interno.	Personal interno o externo con dependencia de la organización.	
Alcance: el Departamento de Informática.	Alcance: cubre todos los componentes de SI de la organización. Orientada a la mejora continua.	

Comparativa

	Auditoría externa	Auditoría interna
Sujeto	Profesional independiente	Empleado
Objetivo	Examen de los estados financieros, operacionales	Control de operaciones y gestión
Origen del encargo	Obligatoria, legal o estatutaria	Voluntaria
Alcance	Estado de los sistemas de información en su conjunto	Restringida departamento informática
Uso del informe	Empresa y público en general	Restringida a empresa o institución pública
Grado de independencia	Total	Limitada
Responsabilidad	Profesional, civil y penal	Profesional
Continuidad del trabajo	Periódico (habitualmente anual)	Continuo
Intensidad del trabajo	Menor	Mayor

4.15. Informes de auditoría

El trabajo de auditoría concluye con un informe, su posterior seguimiento y los cursos de acción que deberían surgir de las recomendaciones que contiene. **El informe refleja las conclusiones a las que llegó el auditor después de desarrollar su programa y recopilar las evidencias de auditoría.** El informe de Auditoría Informática es la comunicación formal del auditor informático al cliente, tanto del alcance de la auditoría (objetivos, periodo de cobertura, naturaleza y extensión del trabajo realizado) como de sus resultados y conclusiones.

Es el momento adecuado para separar lo significativo de lo no significativo, debidamente evaluado según su importancia y su vinculación con el factor riesgo; se trata de una tarea eminentemente profesional y ética, según el criterio del auditor informático.

Aunque no existe un formato vinculante, sí hay esquemas recomendados con los requisitos mínimos aconsejables respecto de la estructura y el contenido.

También es una cuestión previa decidir si el informe será largo o corto, además de otros informes sobre aspectos específicos, como el informe de debilidades del control interno o, incluso, de hechos puntuales.

4.15.1. Estructura básica de un informe de auditoría (Lardent)

1. **Introducción: debe incluir los objetivos de la auditoría, el área o las funciones abarcadas, el periodo que cubrió la revisión y el alcance o la extensión de los procedimientos de auditoría utilizados.**
2. **Descripción de los hallazgos y formulación de recomendaciones: se incluirán las fuentes de evidencia.**
3. **Detalle de las acciones correctivas que se deben desarrollar.**

4. **Opinión del auditor sobre la situación encontrada: se refiere a la adecuación de los controles, a su grado de cumplimiento y a la conclusión sobre los procedimientos sujetos a revisión. La opinión del auditor debe quedar respaldada en el informe mediante las evidencias recopiladas durante la revisión.**
5. **Anexos: su propósito es presentar información muy detallada a la que el lector podrá recurrir o no según sus intereses. Se trata de detalles que pueden ser importantes, pero cuya inclusión en el texto principal podría desviar la atención del lector del tema básico hacia aspectos secundarios. Cuando el informe incluye anexos, debe hacerse referencia en el texto a la información ampliatoria o aclaratoria.**

> **Nota...**
>
> Según Soria, primero debería ir la opinión y después los hallazgos.

4.15.2. Tipos de informes (Lardent)

- **Informe sin salvedades**: significa que la revisión de auditoría *no encontró problemas materiales ni controles débiles no compensados*. Se expresa que «los estados contables están de acuerdo con los principios de contabilidad generalmente aceptados».
- **Informe con salvedades**: *el auditor manifiesta que, si bien los estados contables de la empresa cumplen con las normas de contabilidad generalmente aceptadas, se presenta alguna condición de excepción que debe exponerse expresamente.*
- **Informe con opinión adversa**: los estados contables auditados *no cumplen con las normas* contables generalmente aceptadas o bien no se compensan los *controles débiles encontrados.*
- **Informe sin opinión**: se emite cuando el alcance de la auditoría es limitado o cuando la situación financiera de la organización auditada permite pensar en una posible disolución.

4.16. Auditoría de la Función Informática (Auditoría de Organización y Administración del Ambiente Informático)

La evaluación de la función informática consiste en analizar la organización y la administración del ambiente informático de la organización, asegurándose de que los recursos de TI estén bien gestionados, alineados con los objetivos de la empresa y operando de manera eficiente y efectiva. Corresponde al área de sistemas.

Las funciones específicas del auditor de sistemas de información deben incluir:

- Tener una comprensión precisa del ambiente informático de la organización mediante la identificación de las áreas funcionales que procesan información, así como de sus asignaciones y responsabilidades.
- A partir de esa comprensión, evaluar la estructura organizacional del ambiente informático y verificar su adecuación a las políticas institucionales.

- Evaluar el ambiente de control de la organización para verificar si se cumplen los objetivos de control que otorgan confiabilidad al procesamiento de la información.
- Efectuar pruebas de controles y evaluar sus resultados.
- Detectar las debilidades que puedan existir desde el punto de vista de la gestión y del impacto que producen sobre los procedimientos de auditoría. Las debilidades indicarán la necesidad de concentrar más esfuerzos de auditoría en ciertas áreas.

La auditoría de organización tiene los siguientes **propósitos**:

- Verificar que la estructura organizativa asegure una adecuada separación de funciones, para cumplir con los principios de control interno.
- Asegurar la protección de los archivos, para mantener la continuidad de las operaciones en condiciones normales de procesamiento.
- Verificar la presencia de un buen diseño de control interno, para acotar las deficiencias y los riesgos de procesamiento.
- Verificar que se mantenga un control eficaz en los niveles de autorización de datos y de procedimientos.
- Examinar si existen estándares de actuación y evaluar su adecuación y vigencia.
- Analizar el nivel de formación del personal y evaluar si con él se alcanzan los estándares diseñados.

Elementos a auditar:

Se evalúan las políticas, la administración, la estructura organizativa y la aplicación de controles en un ambiente informático. Esto incluye:

- El plan de organización, que contiene la división de responsabilidades.
- La segregación de funciones (en el departamento de procesamiento de la información).
- El ambiente informático.

4.17. Auditoría del Desarrollo de Sistemas

> ***Se audita para mejorar.*** (Vero)

Según Lardent, el objetivo de este tipo de auditoría es identificar, analizar y evaluar los requerimientos del usuario, así como los riesgos, las exposiciones a riesgos y los *controles* que deben incorporarse a los sistemas de aplicación durante las fases de desarrollo. **Busca verificar que los sistemas se desarrollen siguiendo las metodologías establecidas y que cumplan con los requisitos del negocio.**

Lo importante es identificar los puntos de control.

Lardent plantea la función del auditor como una función asesora que ayuda a definir los puntos de control; el problema es quién realiza después el control. La persona que luego haga la auditoría debe ser distinta de la que ayudó a definir los puntos de control.

Se busca contribuir a la calidad y la confiabilidad del software. La auditoría se puede hacer en cuatro niveles:

- **Revisión del ciclo de vida**: si el área de desarrollo se dedica a desarrollar. Comprende el desarrollo del plan maestro, la evaluación de la factibilidad (que haya una para cada proyecto) y las fases de desarrollo del proyecto (antes de comenzarlo hay que conocer el *framework* que se utilizará).
- **Auditoría de la documentación de sistemas**: propone, por etapa, los documentos que se deben tener.
- **Auditoría de adquisición del software**: analizar la solvencia del proveedor; la recuperación del código fuente (establecer un mecanismo de recupero y definir quién es el propietario); la documentación de respaldo; el nivel de satisfacción de otros clientes, y la capacidad de actualización.
- **Auditoría de modificación de programas**: autorización de los cambios, trazabilidad de los cambios, y documentación de programas y sistemas.

Funciones del auditor:

- Determinar los objetivos y requerimientos básicos de los usuarios del sistema e identificar las áreas afectadas por él.
- Determinar y clasificar los riesgos y las exposiciones a riesgos del sistema.
- Procurar la identificación de los controles necesarios para minimizar los riesgos y las exposiciones a riesgos del sistema (los puntos de control).
- Asesorar a los integrantes del proyecto de desarrollo sobre la incorporación de controles en el diseño y de módulos de auditoría que permitan, una vez implementado el sistema, las revisiones de rutina mediante las pistas de auditoría.
- Asegurar que se sigan los pasos definidos en la metodología de desarrollo aplicada.
- Verificar que se haya efectuado la evaluación de factibilidad y que esta sea consistente y completa.

Según Piattini, la función auditora es la encargada de comprobar la existencia de procedimientos de control y de verificar su correcta definición y aplicación, para determinar las deficiencias que existan al respecto y los **riesgos** asociados a esas carencias de control.

Propone usar la metodología ISACA para evaluar los riesgos definiendo objetivos de control. El auditor evalúa en qué grado se cumplen o no, y para ello existen pruebas asociadas a cada uno de estos criterios (técnicas de control). Para cada elemento que se audita hay n objetivos de control; para cada objetivo, n técnicas, y para cada técnica, una o varias pruebas.

- **Auditoría de la organización**: cómo se administra a las personas. Propone ocho objetivos de control.
- **Auditoría de proyectos**: se elabora un plan distinto para cada proyecto, según sus riesgos, su complejidad y sus recursos.

Comparación entre ambos autores:

- Piattini indica los pasos que hay que seguir; Lardent, solo propuestas generales. Por lo tanto, Lardent es más flexible: el auditor decide en qué punto pone el foco.
- Lardent se enfoca más en el marco institucional y organizacional del desarrollo, con la mirada puesta en la productividad, los costos y los aspectos normativos.
- Piattini propone un enfoque más estructurado y técnico, centrado en la auditoría detallada del ciclo de vida del desarrollo de sistemas, con herramientas y listas de verificación para cada etapa.

Elementos a auditar:

- Plan Maestro (plan de SI/TI).
  - Verificar la concordancia del plan y de los sistemas que incluye.
- Estudio de factibilidad.
- Documentación.
- ERS.
- Metodología utilizada.
- Cada fase del desarrollo del proyecto:
  - Definición y análisis de requerimientos.
  - Diseño lógico del sistema.
  - Diseño físico del sistema.
  - Prueba del sistema.
  - Implantación.
  - Posinstalación (mantenimiento).

> **Nota...**
> **IMPORTANTE: no hay que confundir auditoría con certificación de calidad. La certificación utiliza la auditoría, pero también se puede hacer una auditoría solo para saber si se están haciendo bien las cosas.**

4.18. Auditoría de Sistemas de Aplicación Instalados

Los componentes de los sistemas de aplicación instalados comprenden las funciones de captura e ingreso de datos, de procesamiento de esos datos, de almacenamiento y de salida de información.

Es necesario activar controles sobre esas funciones. Los controles intentan asegurar que:

- En un sistema computarizado solo se ingresen datos completos, exactos, válidos y autorizados (y por única vez).
- La actualización de esos datos se efectúe en los momentos en que realmente corresponda y bajo las mismas condiciones de seguridad señaladas.

- El procesamiento se realice a tiempo y cumpla con el diseño aprobado del sistema según sus objetivos.
- Los datos se mantengan protegidos y actualizados.
- Las salidas (resultados del procesamiento) cumplan las expectativas formuladas al definir el proyecto.

Funciones del auditor:

- Obtener una comprensión profunda de cada aplicación mediante el examen de la documentación y la investigación, para identificar sus componentes significativos y el flujo de datos entre ellos. De ese análisis surgirán las estrategias para desarrollar las pruebas de auditoría.
- Evaluar los controles incorporados a las aplicaciones para identificar sus fortalezas y debilidades, y así definir los objetivos de control.
- Probar los controles existentes para evaluar su funcionalidad, utilizando procedimientos de auditoría adecuados.
- Evaluar el ambiente de control para determinar, a partir del análisis de los resultados de las pruebas, si se alcanzaron sus objetivos.
- Analizar la eficiencia y la eficacia de las operaciones que componen la aplicación, comparándolas con estándares de programación y considerando la tecnología y los procedimientos utilizados.
- Verificar el grado en que la aplicación cumple los objetivos de la gerencia (formulados al definir el sistema).

Elementos a auditar:

- Sistemas de entrada y captura de datos.
- Procesos y métodos de procesamiento de datos.
- Control de la salida.

4.19. Auditoría de Seguridad

Tiene como objetivo verificar el funcionamiento correcto, eficaz y eficiente de los sistemas informáticos, prestando especial atención a aspectos como la seguridad física, la lógica, la de redes y la de los procesos de desarrollo y mantenimiento de los sistemas. Es una rama especializada de la auditoría informática que asegura que los sistemas cumplan con las políticas, normas y estándares establecidos para proteger la información crítica de la organización.

Funciones del auditor:

- Evaluar los controles de acceso para garantizar que solo los usuarios autorizados puedan acceder a los sistemas y datos sensibles.
- Comprobar la protección contra ataques cibernéticos, como virus, *malware* y *phishing*.

- Revisar las políticas de seguridad, los protocolos de encriptación y los sistemas de respaldo de datos.
- Verificar el cumplimiento de las normativas de seguridad (por ejemplo, normas de privacidad de datos o ISO 27001).

Síntesis de los elementos a auditar:

- Controles de acceso a sistemas y datos.
- Protección contra amenazas externas e internas.
- Políticas de seguridad de la información.
- Plan de recuperación ante desastres y copias de seguridad.
- Cumplimiento de las normativas de seguridad.

4.20. Técnicas de evaluación y auditoría

Independientemente de la estrategia seleccionada para la revisión (con o sin computadora), el auditor de sistemas debe desarrollar actividades específicas como las siguientes:

- Verificación de la segregación de funciones.
- Revisión de la documentación de sistemas.
- Un plan de documentación:
  - Definición del problema.
  - Descripción del sistema (análisis y diseño lógico).
  - Descripción de los programas (diseño físico o ingeniería de software).
  - Configuración de registros, diccionarios de datos, esquemas de bases de datos, pantallas e informes.
  - Instrucciones de operación.
  - Descripción de los controles.
  - Registro de aceptación.

> El paso a paso de **cómo se hace el plan de auditoría** se desarrolla en la sección «Apuntes de clase».

4.21. Apuntes de clase (videos)

4.21.1. Definición y finalidad

La auditoría es una opinión profesional; constituye toda un área de especialización de la carrera. Su justificación son los procedimientos: el auditor debe ser impecable en la metodología y los procedimientos.

La finalidad es ver si la realidad responde a los objetivos de funcionamiento y de rendimiento, es decir, cuán fiable es el funcionamiento de ese objeto. Lo que auditamos es el **objeto de audito**.

Tipo de auditoría:

- Financiera.
- Administrativa.
- De gestión de recursos humanos, de calidad.
- De sistemas de información.

El primer video respeta lo que dice Lardent sobre la auditoría de los sistemas de información: **revisión sistemática y organizada** (con una frecuencia y una planificación). Aspectos de los sistemas de información que implica la auditoría de sistemas:

- **Vigencia**: ver si los sistemas de información mantienen vigentes los objetivos planteados como base del diseño original.
- **Concordancia del sistema con los objetivos**: si es efectivo. Si se compara algo con el objetivo y simplemente lo cumple, hay efectividad; es decir, si el sistema sirve para lo que tiene que aportar.
- **Permanencia del diseño por no haber sufrido alteraciones que lo degradaran operativamente**: algo interno afecta el funcionamiento del sistema (por ejemplo, los alumnos aparecen libres en el Sysacad).
- **Eficiencia del sistema**: minimizar costos; cuestiones económicas que se validan con la auditoría, como el costo de mantener el sistema. ¿La práctica de desarrollo es eficiente? Que funcione y que su funcionamiento tenga una relación costo-beneficio lógica.
- **Seguridad del funcionamiento.**

Objeto: se emite una opinión sobre una información en un determinado soporte.

Finalidad: determinar si la información es fidedigna, porque se ajusta a la realidad que representa, o fiable.

Cuando se audita, el panorama se amplía:

- **Posible objeto de audito**: cualquier cosa que afecte la información de la organización:
  - Recursos informáticos.
  - Función de SI: unidad organizativa; la gerencia de sistemas debe ser auditada.
  - Aplicaciones.
  - Proyectos de desarrollo.
  - Planes de contingencia.
  - Almacenamiento de datos.
- **Finalidad**:

  - Operatividad efectiva y segura según las normas establecidas. Por ejemplo, los sistemas bancarios, además de la normativa del propio banco, deben respetar la normativa del Banco Central.

Naturaleza de la auditoría: la nuestra es de los sistemas de información.

- **Objeto**: recursos informáticos, procesamiento de información, planes de contingencia, manejo del riesgo.
- **Finalidad**: garantizar que la información que pasa por esos recursos se procese de un modo fiable o seguro. La información es el insumo para la toma de decisiones, y no se pueden tomar decisiones desacertadas: una información errónea ya no es información.

4.21.2. Aspectos clave de la auditoría de sistemas

- **Control interno informático**: se toma de Piattini; abarca la unidad organizativa y los controles dentro del sistema. Debe haber controles que garanticen que el proceso se realice con todas las características necesarias.
  - **Como función organizativa**: dentro del área de sistemas debe existir un área organizativa encargada de verificar diariamente que las cosas se realicen de acuerdo con un estándar establecido (por ejemplo, validar que los dispositivos del almacén se dejen en los lugares previstos). El video (***que nos generó confusión***) se refiere a que, dentro del área organizativa, debe existir una unidad administrativa que forme parte de la organización.
  - **Misión**: que las medidas implementadas sean correctas y válidas.

Objetivos:

- Están en el Piattini.
- Como unidad, rescata la colaboración entre personas.
- Realizar sobre los diferentes SI, a nivel interno, controles como:
  - Cumplimiento.
  - Controles de producción.
  - Pautas sobre el desarrollo del sistema y la calidad del software.
  - Controles sobre redes.
  - Controles sobre seguridad.
  - Controles sobre licencias y relaciones contractuales.

Diferencia entre control interno informático y auditor informático:

- Ambos son internos y deben ser independientes de la gerencia de sistemas (principio fundamental). Deben ser especialistas.
- El control interno debe verificar todo el tiempo, diariamente, que las medidas se cumplan; el alcance de sus funciones se limita al departamento de SI.

- El auditor informático es quien, en un momento determinado, realiza la evaluación. Siempre necesita la estructura de control interno, que le deben informar los de control interno.

Como unidad organizativa, se denomina Control Interno Informático (CII).

4.21.3. Control interno

Es cualquier actividad que se puede realizar de forma manual o automática para prevenir o corregir errores o irregularidades. Recuerda a las líneas de defensa.

- **Tipos de controles:**
  - **Preventivos**: buscan evitar el hecho; por ejemplo, un software de seguridad que impida los accesos no autorizados al sistema. Previenen riesgos o errores (los errores de los usuarios también son amenazas que hay que prevenir). Es todo aquello que se piensa para evitar que ocurran cosas no deseadas.
  - **Detectivos**: cuando fallan los preventivos, permiten descubrir cuanto antes el evento e impedir su avance. Si hay una intrusión, si algo pasó o se escapó, hay que implementar algo que lo detenga y evite que avance antes de que termine en algo no deseado.
  - **Correctivos**: generalmente orientados a restablecer el funcionamiento de los sistemas si ocurre una irregularidad; son la tercera línea de defensa y devuelven el funcionamiento a la normalidad. Corrigen el error ya producido. Pueden separarse en los que corrigen y los que recuperan.

4.21.4. Implantación de Sistema de controles internos

Para conocer la configuración del sistema es necesario documentar los detalles de la red, así como los distintos niveles de control y los elementos relacionados.

- **Primer paso**: conocer el entorno y todos los elementos relacionados. ***Decidir qué herramienta se implementa es una medida de control interno, y hay que conocerla.***
- Para la implementación del sistema se cuenta con una metodología.
- **Segundo paso**: definir:
  - La gestión de sistemas.
  - La administración de sistemas: base de datos, acceso.
  - La seguridad.
  - La gestión de los cambios del sistema: ***desde la perspectiva de la auditoría, una correcta gestión del cambio brinda cierta garantía de que el diseño original del sistema se mantiene y de que los cambios no afectan su esencia. Es un elemento metodológico y una fuente para la auditoría: hay que ver cómo se van autorizando los cambios.***

4.21.5. Tipos de auditorías

- **Interna**: la realiza una persona que forma parte de la organización y que debe tener independencia de criterio. Lo que ocurre queda dentro de la organización; se reporta a la máxima autoridad, y el auditor interno no puede depender del gerente o director de sistemas.
  - Función asesora de control.
  - Pertenece a la empresa (vínculo laboral).
  - No tiene autoridad de línea: solo recomienda, por lo que se convierte en autoridad de staff.
  - No puede involucrarse ni comprometerse con las funciones de la empresa.
  - Es permanente, con una frecuencia y un cronograma: es una revisión sistemática.
  - Es crítica, sistemática y detallada, con vínculo laboral con la organización. Sus dictámenes quedan puertas adentro; no está en juego la fe pública.
- **Externa**: la realiza alguien de afuera, sin vínculo con la organización o con el área. Es el examen crítico y sistemático de un sistema de una unidad económica (empresa), cuya finalidad es verificar que los sistemas operen y ver qué aspectos críticos pueden tener impacto en el negocio. Su cualidad es la fe pública. Reporta a organismos oficiales públicos o a determinadas empresas (por ejemplo, cuando se hace una auditoría de calidad de productos o procesos, audita un ente certificador). Características:
  - Tiene implicancias legales: si se importan aplicaciones y están mal, pueden denunciar.
  - La realizan profesionales con certificación.
  - El auditor es designado por alguien de afuera o por entidades externas con auditores definidos, sin vínculo laboral.
  - Su periodicidad es puntual (un momento determinado).
  - Es el examen de un profesional informático o contador público sin vínculos de ningún tipo con la organización, y sus reportes tienen fe pública. Ejemplo sobre el PAMI en el campus: son de interés público, por lo que se necesita auditoría externa. No necesariamente es el mismo auditor quien realiza el seguimiento.

4.21.6. Comparación entre el control interno, auditoría interna informática y auditoría externa informática

> **Nota.**
>
> *Ver el cuadro de la sección 4.14.*

Auditoría externa informática:

- Abarca todos los sistemas y las TI que tengan impacto público.
- ***Lo que una organización/empresa debe demostrarle al auditor externo es que cumple con los tres aspectos del management seguro de los SI.***

4.21.7. Aspectos procedimentales claves de la auditoría - etapas de la auditoría

4.21.7.1. Cómo se hace el plan de auditoría

1. **Identificar el alcance y los objetivos de auditoría CON RESPECTO AL objeto:** no se puede empezar sin hacer esto. Se define, de manera general, qué se audita (alcance) y para qué (objetivo), y, si es externa, quién la encarga.
    1. El **alcance** es hasta dónde llega la evaluación: qué entra y qué queda afuera. Debe quedar claro.
    2. Los **objetivos** indican para qué se hará la auditoría. Se describen todos los objetos de audito. **Objeto de audito y sujeto son sinónimos.**
2. **Realizar el estudio inicial del entorno que se auditará:** arquitectura, distribución, quiénes son las fuentes de evidencia, interlocutores, y verificar si existe un área de control interno.
3. **Ejecución del programa de revisión:** se sigue la metodología que corresponda y se desglosan el alcance y el objetivo en partes.
    1. **Qué es el programa de revisión:** un conjunto de instrucciones que guía a quienes llevan a cabo la auditoría. Una vez que se tiene el plan general, estos programas son flexibles: se puede agregar, quitar o posponer. Se detallan el alcance, los objetivos y el objeto de audito para esa parte del todo. Se elabora un programa por cada área que se auditará (por ejemplo, si en el plan hay dos áreas, se hacen dos programas).

        > Es literalmente el documento operativo (la «receta paso a paso» u hoja de ruta con una planilla de control) para auditar una sección o área específica. Dice exactamente: qué vamos a mirar en esa área, para qué, qué documentos o sistemas vamos a pedir, quiénes lo van a hacer y qué pruebas concretas va a ejecutar cada uno.

    2. **Fuentes de evidencia:** aquello en lo que uno se basa para obtener hallazgos. Si se audita la organización del área informática, una fuente de evidencia puede ser el organigrama, las políticas o el manual del área.
    3. **Equipo de auditoría:** perfiles informáticos que forman parte del grupo. ¿Cuál es el perfil de un auditor informático? Debe tener título y habilidades técnicas en seguridad informática, redes, inteligencia artificial, infraestructura, ciberestructura y derecho informático. Conocer los perfiles sirve para saber cómo conformar el equipo.
    4. **Puntos a controlar:** para cada objetivo hay una serie de puntos a controlar: responsable, fecha de inicio, puntos de control y condición inicial (por ejemplo, tener agendada una reunión). El programa de ejemplo es lo más parecido al lugar donde se plasman los procedimientos.
    5. **Procedimientos:** garantizan que el trabajo esté bien hecho. Tipos de pruebas: de cumplimiento (documentación; verificar si están los reglamentos; pruebas de detalle y de indagación y observación) y sustantivas (tratamiento de la información: se va a los sistemas y se observa cómo operan la información).

4. **Cierre de la revisión:** estudio de las evidencias recolectadas.
5. **Realizar el informe final:** no hay auditoría sin informe final, y este requiere firma. El informe de auditoría expone en forma sintética todo lo que se hizo y apunta directamente a los hallazgos:
    - Primero va la **opinión**, en la que los auditores se pronuncian sobre el funcionamiento del sistema: puede ser favorable («razonablemente bien»), con salvedades (hay que corregir cosas) o adversa / de no conformidades («totalmente apartado»).
    - Luego van las **recomendaciones**, que deben ayudar a mejorar.
6. **Seguimiento:** se verifica si se llevaron adelante las recomendaciones, si fueron efectivas y si corrigieron las observaciones realizadas. Lo hace el auditor, y uno de sus insumos son todos los reportes de auditoría anteriores. Si la organización no tiene impacto social (en los bancos sí o sí lo tiene), se realizan auditorías internas y se deben aplicar las recomendaciones. Con dos dictámenes seguidos con disconformidades, no se certifica.

¿Cómo se relacionan estos pasos con las etapas genéricas de la ISACA?

1. **Planeación:** se relaciona con los **dos primeros pasos** (identificar alcance/objetivos y estudio inicial), porque a partir de la revisión inicial se planifica.
2. **Trabajo de campo y documentación:** corresponde al **paso 3** (ejecución del programa de revisión), donde se sale a aplicar la planificación y se documentan las fuentes de evidencia (algo que se está separando de la norma).
3. **Reporte y seguimiento:** abarca los **pasos 4, 5 y 6**, ya que el reporte comprende el cierre de la revisión y la elaboración del informe final, seguido de la verificación posterior de las recomendaciones.

AUDITORÍA
PROGRAMA DE REVISIÓN

01

Definición de la Naturaleza, Oportunidad, Alcance, y según el plan general de AI

- Objeto de audito
- Qué se evaluará de dicho objeto
- Que no se evaluará



02

Descripción de los objetivos de auditoría

¿Para qué se evaluará?
Cada objetivo implicará un procedimiento (secuencia de pruebas y actividades a realizar)



03

Determinar las potenciales fuentes de evidencias



04

Definir el Equipo de auditoría

Roles y funciones, y cantidad según naturaleza, alcance y objeto de audito



05

Programa específico

Por cada objetivo: pruebas, actividades, hitos de revisión, presentación de informes parciales, el tiempo estimado, el tiempo real, la referencia al papel de trabajo donde quedó plasmada la ejecución del programa, la rubrica de quien realizó cada paso y la fecha del mismo.
Condiciones o situaciones que requieran toma de decisiones.



4.21.8. Importancia de procedimientos

- Son el método que se sigue para garantizar que todo lo que se releva y sobre lo que se fundamenta la opinión sea correcto. Proporcionan una seguridad razonable de lo que se afirma.
- El auditor es una persona procedimental: se ajusta a la metodología o al programa de revisión establecido.
- Los procedimientos determinan la trascendencia de la auditoría, es decir, el impacto que tiene. Si se hacen bien las cosas, surgen hallazgos y se cumple la finalidad.

4.21.9. Tipos de prueba

- **Pruebas de cumplimiento**: determinan si los controles se ajustan a las políticas; su insumo es la documentación. Por ejemplo, si según el organigrama hay un área de programación y otra de *testing*, ¿se trata de personal distinto o de personal multitarea? Si se indica que hay personal distinto, con funciones separadas, hay que verificar que se cumpla, y para eso se usa la documentación. Se puede hacer una entrevista para saber si todos conocen el procedimiento de gestión del cambio, es decir, si se cumple lo definido, lo escrito, los patrones establecidos. A partir de aquí se distinguen:
  - **Pruebas de cumplimiento de detalles**: por ejemplo, validar un usuario o la condición del alumno. Consisten en la revisión de documentos.
  - **Pruebas de indagación y observación**: si la persona dice conocer el procedimiento de gestión del cambio, se vuelve otro día para ver si realmente sabe cómo actuar. También, observar el comportamiento de los programas de edición ante situaciones simuladas que generen errores en el ingreso de datos.
- **Pruebas sustantivas**: se prueban los sistemas; apuntan al tratamiento de la información y garantizan que el sistema hace lo que tiene que hacer y que no se alteran los resultados, para proteger la información ante acciones fraudulentas. **Preservar copias de seguridad de los datos y ver cómo se hacen (en qué servidor, quiénes tienen acceso) es una prueba sustantiva. Se pueden cruzar datos, usando herramientas informáticas, para ver si alguna aplicación altera las salidas de otra.**
  - Por ejemplo, se establece el procesamiento en dos servidores distintos y se hace un cruzamiento de datos: la base de datos se procesa en ambos servidores y se comparan los resultados. Si la aplicación evaluada arroja resultados contables distintos en dos servidores con el mismo conjunto de datos, hay un problema.

4.21.10. Objetos (secciones) o áreas de la auditoría informática

Según Lardent:

- **Evaluación de la función informática** (organización y administración del ambiente informático): el área de sistemas.
- **Evaluación de los sistemas y procedimientos:**

  - Auditoría del desarrollo.
  - Auditoría de sistemas instalados (se les hacen pruebas sustantivas: todo lo que procese información).
- **Evaluación del proceso de datos.**
- **Evaluación de la seguridad**: se audita la seguridad como un objeto de audito más; ***auditoría y seguridad no son sinónimos***.
- **Evaluación de los aspectos legales de los sistemas y de la información.**

4.21.11. Riesgos del auditor (Etapa inicial)

Riesgo de la auditoría: aunque el auditor esté muy formado, como en cualquier ejercicio profesional, existe un riesgo. Puede entenderse como riesgo de auditoría la posibilidad de que la información obtenida tenga algún tipo de error o de que no se pueda detectar un error ocurrido.

- **Inherente**: propio de la naturaleza de la actividad y de la organización en la que se encuentran los sistemas. Generalmente se relaciona con la actividad; por eso hay auditores especializados en diferentes áreas, ya que depende del área, la empresa y la actividad realizada. Ejemplo: se puede hacer una auditoría de la función informática, pero, si se trata de una empresa de desarrollo de sistemas, la profesora no estaría capacitada porque no conoce de desarrollo: hay muchas cuestiones asociadas a no dominar la naturaleza de lo que se audita. **SIEMPRE hay que tener idea de la empresa y de la actividad que se auditará para reducir el riesgo inherente.** Se puede reducir mediante el estudio del objeto de audito.
- **Propios del control**: se da cuando hay algo que el sistema de control interno no detecta; algo que no se puede auditar o que se pasó por alto porque el propio sistema de control no lo verifica. Si el auditor lo advierte, es un hallazgo. Ocurre cuando el error material no pudo ser evitado ni detectado por el sistema de control interno: no hay medidas de control establecidas y, por lo tanto, no hay con qué contrastar.
- **Detección**: se da cuando se hacen pruebas exitosas que no detectan errores porque los procedimientos son inadecuados. Es el riesgo que corre el auditor cuando realiza pruebas «exitosas» (sin detectar errores) a partir de procedimientos de prueba inadecuados. Que se advierta un procedimiento inadecuado depende de la calidad del auditor; si no lo advierte, el riesgo se concreta.
  - Otra definición: es el peligro que se corre cuando el procedimiento es inadecuado; implica responsabilidad profesional y se relaciona con la materialidad. Según cuán rápido ocurra el riesgo, puede tener un costo económico.

El concepto de riesgo está relacionado con el de materialidad, que se refiere a la magnitud del error en términos de su impacto potencial para el conjunto de la organización. En general, esa materialidad se expresa en términos monetarios.

4.21.11.1. Cuadro comparativo para distinguirlos rápido

Tipo de Riesgo	¿Dónde nace el problema?	¿Quién es el responsable?	¿Cómo actúa el auditor frente a él?	Ejemplo práctico
1. Inherente	En la **naturaleza misma del negocio**, la tecnología o la actividad auditada.	Nadie en particular (es intrínseco a la actividad de la empresa).	No puede eliminarlo. Lo reduce haciendo un buen **estudio inicial del entorno** y sumando especialistas al equipo.	Auditar una empresa de desarrollo de software sin conocer cómo funciona el ciclo de desarrollo, o auditar transacciones bancarias en línea de alta complejidad.
2. De Control	En las **deficiencias o huecos del Control Interno** de la empresa.	La Dirección / el área de Control Interno de la empresa.	No puede eliminarlo por sí mismo, pero **lo detecta como hallazgo y emite recomendaciones** para corregirlo.	La empresa no tiene controles de validación en la entrada de datos ni alarmas ante accesos no autorizados, por lo que entran datos corruptos sin que nadie se entere.
3. De Detección	En un **procedimiento de prueba mal elegido o mal aplicado** durante la auditoría.	**Exclusivamente el auditor** (afecta su responsabilidad profesional).	Lo controla y reduce directamente usando **buenos procedimientos, muestras amplias y pruebas rigurosas**.	Hay datos corruptos en la base de datos, pero el auditor revisa una muestra minúscula o usa un script mal programado, no ve el error y firma que el sistema funciona bien.

4.21.12. Deontología

- 25 principios deontológicos del auditor:
  - Sin sesgo: sin opinión adelantada hacia el equipo.
  - De todos los principios, uno importante es el **principio de independencia**: independencia de criterio. En las auditorías externas es más fácil de lograr; en la interna debe garantizarse mediante la estructura organizativa: el auditor no puede depender de la gerencia, no puede tener autoridad lineal sobre el área a la que sirve y no debe estar subordinado al área de control interno. Tampoco puede participar en el área de desarrollo. Cuestiones que se pueden incorporar en una aplicación para que sirvan como pistas de auditoría: contador de transacciones, registros de *logs*.

4.21.13. ¿Por qué auditar desarrollo?

Para mejorar: la auditoría es una manera de medir, y midiendo se mejora. Siempre que se realiza un proceso de auditoría, se deben tomar las acciones necesarias para solucionar los inconvenientes encontrados. Así como un *test* es bueno cuando encuentra errores, una auditoría es buena cuando encuentra cosas para mejorar.

- Verificar la conformidad.
- Detectar errores.
- Mejorar la calidad.
- Promover la mejora.
- Responsabilidad y transparencia: qué historia de usuario (HU) genera esta funcionalidad, que a su vez genera casos de prueba.
- Evaluar el cumplimiento de los requisitos.

4.21.14. La auditoría en el área de desarrollo (Lardent y Piattini)

Lardent: el objetivo es identificar, analizar y evaluar los requerimientos, identificando los riesgos, la exposición a ellos y los controles que se incorporan al área de desarrollo para minimizarlos.

- **IDENTIFICAR puntos de control**: el auditor los identifica; Lardent indica un conjunto de acciones o actividades generales, a diferencia de Piattini.
- **La función del auditor es una función asesora**: se plantea una discusión sobre cómo debería ser el auditor. Se debe auditar desde el área de desarrollo, y el auditor debe tener una función más bien asesora para definir los puntos de control. Si el auditor define o ayuda a armar los puntos de control, ¿quién hace el control después? Lardent propone que quien haga luego la auditoría sea una persona distinta de la que definió los puntos de control. Funciones:
  - Determinar los objetivos.
  - Clasificar los riesgos a grandes rasgos.
  - Identificar los controles necesarios.
  - Asegurar que se sigan los pasos propuestos por la metodología de desarrollo.
- El auditor cumple un papel activo: trabaja a la par de las personas que seleccionan los procesos. Es una consultoría en las fases del ciclo de vida.
- Se busca contribuir a la calidad y la confiabilidad.
- **Cuatro niveles:**
  - **Revisión del ciclo de vida:**
    - Si el área de desarrollo produce software.
    - Se parte del desarrollo del plan maestro: plan de SI/TI, recursos, cronograma y prioridades. Hay que verificar su existencia, que esté estructurado para determinar en

qué etapa se encuentra cada aplicación y que sea flexible por si surgen inconvenientes. Son pasos muy generales: no indica el cómo.

    * Una vez asegurado el plan maestro, se define un punto de control para evaluar la factibilidad de cada uno de los proyectos del plan maestro que se implementarán en los próximos cinco años. Pasos: revisar la documentación, verificar si se definieron fechas para comenzar el desarrollo, si se consideraron soluciones alternativas y si existe un estudio de justificación económica. No indica el cómo: es responsabilidad del auditor.
    * Una vez definidos los puntos de control, se pasa a las fases de desarrollo del proyecto propuestas por las metodologías clásicas: para cada etapa, un conjunto de actividades (cap. 25 de Lardent). Según la metodología o el *framework*, se deben hacer determinadas actividades o no; si es ágil, depende de si aportan valor. Lardent es más flexible porque no es tan estructurado.

- **Auditoría de la documentación de sistemas:**
    * Que cumpla con los estándares de la organización: por ejemplo, si se debe certificar CMMI, hay que cumplir con la documentación técnica.
    * Propone aspectos que se deben tener en cuenta en cada una de las etapas mencionadas.
    * Incluye la posinstalación (mantenimiento).
- **Auditoría de la adquisición de software:**
    * Cuando se compra el software a un proveedor externo, se analiza su solvencia: su historial económico, qué casos de venta tuvo y qué soporte brinda después de la adquisición.
    * Cómo se recupera el código fuente: con software enlatado no hay problema, pero si se contrata a una persona para que desarrolle, es necesario definir estos mecanismos y de quién es el código. Si se rompe la relación y se deja de brindar el servicio, ¿qué pasa con ese código? Hay que controlarlo. Son cuestiones legales y contractuales: el código fuente es propiedad intelectual, es el desarrollo de una persona. Es importante para la provisión.
    * Documentación de respaldo.
    * Nivel de satisfacción.
    * Capacidad del proveedor para realizar actualizaciones: cómo se personaliza el producto; si se contrata un desarrollo, cada cuánto se pueden añadir funcionalidades.
- **Modificación de programas:**
    * Poder saber por qué se hizo un cambio (trazabilidad del cambio).
    * Quién autorizó el cambio.
    * Concordancia entre el código fuente y el código objeto: lo que había antes y lo que hay ahora.
    * Documentación: cualquier registro que muestre por qué se hizo el cambio.
    * Documentación de sistemas: manuales de usuario.
    * Todo tiene que estar relacionado, con puntos de control que permitan ver esa relación.

Lardent propone áreas que se pueden auditar; para cada una se establecen puntos de control, e indica qué actividades deben seguirse para establecerlos. La persona que los establece es distinta de la que los evalúa.

Piattini (cap. 22): es muy estructurado; define procedimientos claros y no tiene agilidad. Métrica v3 es la «cascada española», metodología de desarrollo definida por Piattini que deriva de normas ISO.

Piattini sostiene que la función auditora (una función dentro de la empresa) es la encargada de comprobar la existencia de procedimientos de control, verificar su correcta definición y aplicación, y determinar sus deficiencias y los riesgos asociados. Propone usar la metodología ISACA: evaluar los riesgos a partir de los riesgos potenciales a los que está sometida una actividad, definiendo objetivos de control. Para cada objetivo se definen criterios, y la función del auditor es determinar su grado de cumplimiento; Piattini define pruebas asociadas a los criterios establecidos. Hay N objetivos de control; para cada uno, una o varias técnicas de control asociadas, y para cada técnica, una o varias pruebas de cumplimiento.

- **Auditoría de la organización y gestión del área de desarrollo:**
  - Desde el punto de vista de las personas y de cómo trabajan.
  - Propone ocho objetivos de control, divididos en niveles de la A a la G según el nivel de tecnicismo de cada objetivo (están en el libro). La actividad del auditor es más ordenada y tiene una guía clara; Piattini ve al auditor más como una función asesora.
- **Auditoría de proyectos de desarrollo de sistemas de información:**
  - (El primer punto no quedó registrado en el apunte).
  - Aprobación, planificación y gestión del proyecto.

> **Pregunta pendiente (para la próxima clase):** ¿dónde se ubica el Sysacad en este esquema?

4.21.15. Niveles de emergencia planteados por Lardent

- **Catástrofe**: se perdió todo.
- **Desastres.**
- **No desastres.**

Cold sites: no tienen infraestructura.

En cuanto al contenido del plan de contingencia, la profesora Soria agregó la disponibilidad de las telecomunicaciones y de las redes de energía.

4.21.16. Taller de Laboratorio asociado

Diseño e implementación de esquemas de líneas preventivas, de detección y de recuperación de accesos a recursos, sobre la base de un análisis de riesgo para un caso de estudio.

5. Extras

Apunte de una clase

5.1. Cuestionario Parte I - Seguridad de SI/TI

1. ¿Qué es el delito informático? ¿Quiénes son sus artífices y con qué modalidad operan?

> Lo que puse a continuación es un montón, pero lo agrego igual porque me gustó...

5.1.1. 1. ¿Qué es el delito informático?

Según **Emilio del Peso y Mario Piattini** (la definición exacta incluida en la sección *3.3.* de tu apunte):

> *«Se denomina **delito informático** a toda acción (u omisión) culpable realizada por un ser humano, que cause perjuicio a otras personas sin que necesariamente se beneficie el autor o que, por el contrario, produzca un beneficio ilícito a su autor aunque no perjudique de forma directa o indirecta a la víctima, **tipificado por la ley**, que se realiza en un **entorno informático** y está **sancionado con una pena**».*

- **Características clave:**
- Los sistemas de información y las computadoras pueden funcionar tanto como el **medio o instrumento** para cometer el ilícito (por ejemplo, una estafa financiera alterando registros contables) como el **fin u objeto** del delito en sí mismo (por ejemplo, el sabotaje informático, la destrucción de bases de datos o la piratería de software).
- Se los cataloga como **«delitos de cuello blanco»**: requieren conocimientos técnicos específicos, ocurren sin violencia física visible, a distancia y en fracciones de segundo, dejando muy poco rastro físico, lo que genera una alta complejidad probatoria.
- En un sentido amplio, abarcan tres grandes grupos de figuras delictivas: **delitos contra la intimidad** (descubrimiento y revelación de secretos o datos personales), **delitos contra el patrimonio** (estafas informáticas, defraudaciones, daños a datos/programas y violación de propiedad intelectual) y **falsedades documentales** (como la falsificación de tarjetas o documentos electrónicos).

5.1.2. 2. ¿Quiénes son sus artífices (sujetos activos)?

Lardent y Piattini clasifican a los causantes de violaciones y delitos informáticos según su vínculo con la organización, su nivel técnico y su motivación:

1. **Personal interno y ex-empleados (*Insiders*):** Estadísticamente representan la **mayor fuente de riesgo** para cualquier organización. Conocen en detalle los procedimientos, las debilidades de los controles internos, las claves y las rutas de acceso (incluyen operadores, programadores, administradores de bases de datos o usuarios finales deshonestos o disconformes). Por esto es vital aplicar la segregación de funciones.
2. **Hackers:** Son individuos con profundos conocimientos técnicos en sistemas, programación y redes que buscan demostrar su habilidad para burlar los controles y acceder a información reservada por desafío intelectual o curiosidad. Aunque en principio su propósito no suele ser destruir información, el resultado final sí puede ocasionar daños graves.
3. **Crackers:** Sujetos con altos conocimientos técnicos que operan con **fines maliciosos, de lucro ilícito o contratados por terceros**. Irrumpen en los sistemas para destruir datos, denegar servicios, cometer fraudes, robar información o desproteger software comercial.
4. **Phreakers:** Especialistas que intentan ingresar y manipular ilegalmente los **sistemas de telecomunicaciones y redes telefónicas** para interceptar transmisiones o utilizar los servicios de comunicación sin pagar.
5. **Piratas informáticos / Bucaneros:** Personas u organizaciones dedicadas a la copia, reproducción, distribución y comercialización ilegal de software o datos protegidos por derechos de autor (propiedad intelectual).
6. **Lamers (*Script-kiddies*):** Usuarios sin conocimientos técnicos profundos que descargan y ejecutan herramientas de ataque automatizadas, virus o *scripts* armados por terceros para causar daño.
7. **Espías industriales / Intrusos remunerados / Ciberterroristas:** Profesionales contratados por competidores u organizaciones criminales para sustraer secretos industriales, sabotear infraestructura crítica o extorsionar.

5.1.3. 3. ¿Con qué modalidad operan?

Esta parte de la pregunta se responde en **dos niveles**: las categorías generales de ataque a la información (sección *3.3.* del apunte) y las técnicas operativas específicas de fraude informático (Capítulo 22 de Lardent):

5.1.3.1. A. Modalidades generales de ataque al flujo de información

Se dividen en **ataques pasivos** (el intruso solo escucha o monitorea sin alterar los datos) y **ataques activos** (alteran el flujo de datos o crean flujos falsos, como la *suplantación de identidad*, la *reactuación/repetición de mensajes*, la *modificación de mensajes* y la *degradación fraudulenta del servicio*), agrupándose en cuatro categorías:

- **Interrupción (contra la disponibilidad):** Destruir un recurso del sistema o dejarlo inutilizable (ej. dañar un disco duro o cortar una línea de comunicación).
- **Intercepción (contra la confidencialidad):** Acceder sin autorización a un recurso (ej. pinchar una línea de red o copiar ilícitamente archivos).
- **Modificación (contra la integridad):** Acceder a un recurso y además manipular su contenido (ej. cambiar saldos en un archivo o alterar el código de un programa).
- **Fabricación (contra la autenticidad):** Insertar objetos o registros falsificados en el sistema (ej. inyectar mensajes espurios en la red o agregar registros falsos a una base de datos).

5.1.3.2. B. Técnicas específicas para cometer delitos informáticos (Lardent)

- **Alteración o manipulación de datos de entrada (*Data Diddling*):** Es la técnica más frecuente y sencilla. Se realiza antes de que se active el sistema de protección y consiste en modificar, falsificar u omitir datos antes o durante su ingreso a la computadora (cualquier persona que intervenga en la creación, grabación o codificación puede hacerlo).
- **Caballos de Troya (*Trojan Horse*):** Consiste en introducir de forma encubierta, dentro de un programa autorizado y de uso habitual, un grupo de instrucciones ocultas con fines maliciosos que se ejecutan sin levantar sospechas cada vez que corre el programa legítimo (por ejemplo, para robar contraseñas o desviar dinero en una liquidación de sueldos).
- **Técnica del salame (*Salami Technique*) y Redondeo por defecto (*Rounding Down*):** Modalidades de fraude financiero automatizado que consisten en retirar pequeñas cantidades o fracciones de centavos (producto del redondeo hacia abajo en cálculos de intereses o liquidaciones) de miles de cuentas o transacciones para desviarlas y acumularlas en una cuenta no autorizada.
- **Superzapping (*Llave maestra*):** Uso fraudulento de un programa utilitario de emergencia del sistema que permite burlar todos los controles de seguridad y acceder directamente a los archivos o bases de datos almacenados para modificarlos sin dejar rastro en las pistas de auditoría.
- **Virus informáticos, Gusanos y Bombas lógicas/de tiempo:**
- Los **virus** son programas que se autoduplican desplazándose entre computadoras (por red, correo o soportes magnéticos) para destruir o dañar datos.
- Las **bombas lógicas o de tiempo** son instrucciones destructivas que permanecen inactivas (latentes) dentro de un programa hasta que un acontecimiento determinado o una fecha específica activa su poder destructivo.
- Los **gusanos** destruyen datos o saturan recursos de computación y redes hasta colapsarlas, pero sin necesitar infectar un archivo anfitrión como los virus.

- **Puertas traseras o falsas (*Trap Doors / Backdoors*):** Instrucciones o accesos secretos insertados maliciosamente por los programadores en un programa autorizado (o dejados desde la etapa de desarrollo/depuración) para saltarse los controles de autenticación e introducir rutinas no autorizadas.
- **Ingreso a caballito de otro (*Piggy-backing*):** Consiste en conectar una línea de comunicaciones a una computadora o sesión ya autorizada para interceptar los datos de la transmisión y alterarlos (o aprovechar la sesión abierta de un usuario legítimo).
- **Ataque asincrónico:** Aprovecha el momento en que los datos en líneas de telecomunicaciones asincrónicas quedan en espera de que la línea esté libre antes de ser transmitidos, quedando expuestos a accesos o alteraciones no autorizadas.
- **Recolección de residuos (*Scavenging*) y Fuga de datos:** Extraer información confidencial del equipo de computación, ya sea revisando listados impresos desechados o leyendo sectores de memoria y almacenamiento que otros usuarios utilizaron y dejaron sin borrar.

5.2. Cuestionario Parte II. Auditoría de SI/TI

5.2.1. ¿Qué es la auditoría de sistemas de información?

La auditoría de sistemas de información es un componente de la Auditoría General, y sus funciones integran el plan y los esfuerzos de esta. La auditoría de sistemas ha sido **definida como la revisión sistemática y organizada de los sistemas en funcionamiento para ver si en ellos se verifican las propiedades de:**

- Vigencia de los objetivos planteados como base del diseño original.
- Concordancia del sistema con los objetivos (si es efectivo).
- Permanencia del diseño por no haber sufrido alteraciones que lo degradaran operativamente.
- Eficiencia del sistema.

5.2.2. ¿Qué es el control interno? Desarrolle las clasificaciones de control. Ejemplifique cada una.

El control interno comprende el **plan de organización, los métodos coordinados y las medidas adoptadas** dentro de una empresa para:

- Salvaguardar sus activos.
- Verificar la confiabilidad y la corrección de los datos contables.
- Promover la eficiencia operativa.
- Fomentar la adhesión a las políticas administrativas.

Clasificación de controles (tres categorías):

Denominación	Descripción	Ejemplo
Preventivo	Diseñado para evitar que se produzca un error, una omisión o un acto doloso.	Controlar mediante software el acceso a la información sensible, para que solo las personas autorizadas puedan entrar a esos archivos.
Correctivo	Corrige errores, omisiones o actos dolosos.	Software que coloca automáticamente la fecha actual si la fecha ingresada es incorrecta o no se escribió.
De detección	Detecta que se ha producido un error, una omisión o un acto malicioso e informa de su aparición.	Software de seguridad que guarda un registro cuando alguien intenta entrar sin permiso.

5.2.3. ¿Cuáles son los tipos de prueba que se requieren en la Auditoría de SI?

Hay dos tipos de pruebas:

- **Pruebas de cumplimiento**: determinan si los controles se ajustan a las políticas y procedimientos de la organización, y si se aplican conforme a la descripción de la documentación de los programas de computación. En pocas palabras: determinan si un control funciona efectivamente y si logra sus objetivos.
- **Pruebas sustantivas**: se hacen para ver si los controles de la organización realmente ayudan a evitar fraudes. Por ejemplo, una Auditoría de Sistemas de Información aplicaría una prueba sustantiva para determinar si el inventario de la biblioteca de cintas está registrado adecuadamente.

5.2.4. Para cada área de Auditoría determine: i. Concepto; ii. Funciones del Auditor; iii. Síntesis de los elementos a auditar

A continuación se presentan, para cada área de auditoría informática descrita en las fuentes, el concepto, las funciones del auditor y los elementos a auditar, con foco en la seguridad y los procedimientos de los sistemas de información.

5.2.4.1. Auditoría de Sistemas de Información (Capítulo 20)

- **Concepto**: es un examen independiente de los sistemas de información, procedimientos, operaciones y controles de una organización para determinar si las medidas de seguridad son adecuadas y si se cumplen las políticas y procedimientos establecidos. Su objetivo es identificar, analizar y evaluar los riesgos y las exposiciones de los sistemas, identificar problemas y proponer

mejoras. La auditoría debe ser objetiva e independiente. Se consideran el enfoque, los elementos clave y las tendencias.

- **Funciones del Auditor**: evalúa, verifica, determina, mide, identifica problemas y recomienda mejoras. Planifica la auditoría, realiza pruebas, y analiza y documenta los resultados. Se enfoca en la evaluación del control interno, el cumplimiento de las políticas, la eficiencia y la eficacia.
- **Elementos a auditar**: los controles (preventivos, correctivos y de detección); los sistemas, procedimientos y operaciones; los riesgos y exposiciones; la eficiencia y eficacia de los sistemas; los controles en el procesamiento electrónico de datos; los estándares de operatividad; la segregación de funciones; la evidencia de auditoría; los factores que afectan la complejidad (objetivos, evidencia, características de las aplicaciones, controlabilidad, estabilidad, criticidad, técnica), y la documentación relacionada.

5.2.4.2. Auditoría de Organización y Administración del Ambiente Informático (Capítulo 21)

- **Concepto**: se centra en evaluar las políticas, la estructura administrativa y las funciones de control dentro del ambiente informático. Busca asegurar que la gestión del ambiente informático apoye los objetivos generales de control de la gerencia. Incluye la revisión de los aspectos lógicos y físicos del ambiente.
- **Funciones del Auditor**: evalúa las políticas y la estructura; verifica la segregación de funciones y responsabilidades; asegura el cumplimiento de los principios de control interno; verifica la seguridad del acceso físico; examina la documentación; analiza el nivel de formación del personal. Revisa el plan de organización y las funciones de proyecto y de procesamiento de información. Evalúa los controles de acceso lógico y físico. Verifica la adhesión a los estándares.
- **Elementos a auditar**: las políticas; la estructura organizativa; la segregación de funciones y la asignación de responsabilidades; los principios de control interno; la seguridad del acceso físico; la documentación; el nivel del personal (formación, rotación); las funciones de proyecto, de procesamiento de información y de soporte técnico; los estándares de operatividad, y los controles (generales, de aplicación, lógicos y físicos).

5.2.4.3. Controles de Accesos Lógicos y Físicos (Capítulo 22)

- **Concepto**: el capítulo se basa en el análisis del control interno necesario para salvaguardar la información, con foco en la revisión y la evaluación de los controles de acceso lógico y físico. Se ocupa de cómo se asegura el acceso a los recursos.
- **Funciones del Auditor**: verificar el cumplimiento de las políticas de seguridad, evaluar la seguridad del ambiente físico y verificar los controles activos. Revisa las rutas de acceso lógico y físico, realiza pruebas sobre los controles (por ejemplo, contraseñas) y documenta los hallazgos.
- **Elementos a auditar**: las políticas de seguridad; la seguridad del ambiente físico (personal, vigilancia, cerraduras, tarjetas de acceso, ubicación de los equipos); los controles lógicos activos; las rutas de acceso lógico (centralizado, red de área local, entre computadoras, terminales remotas, otros dispositivos); los controles físicos y lógicos por etapas (prevención, detección, recuperación); los criterios de autorización de usuarios (claves, límites de transacción, límites monetarios); los controles de comunicación, y los controles de acceso remoto.

5.2.4.4. Seguridad en los sistemas de base de datos (Capítulo 23)

- **Concepto**: examina los controles dentro de los sistemas de base de datos para asegurar la fiabilidad y la disponibilidad de un gran volumen de datos. Cubre aspectos como el acceso, las operaciones, el mantenimiento y la seguridad del ambiente de base de datos.
- **Funciones del Auditor**: verificar la fiabilidad y la disponibilidad del sistema; auditar los controles de acceso (por usuario y por programa), las operaciones y el mantenimiento, y la seguridad. Verificar la documentación. Evaluar las funciones y responsabilidades de la administración de la base de datos. Revisar los *logs*. Comprobar los procedimientos de respaldo y recuperación. Verificar la integridad y la consistencia de los datos.
- **Elementos a auditar**: la fiabilidad y la disponibilidad del sistema de base de datos; los controles de acceso (por usuario y por programa de aplicación); los controles sobre las operaciones, el mantenimiento y la seguridad; la documentación; las funciones y responsabilidades de la administración de la base de datos; los *logs*; los procedimientos de respaldo y recuperación; la integridad y la consistencia de los datos, y las modificaciones a los programas.

5.2.4.5. Seguridad de redes y sistemas distribuidos (Capítulo 24)

- **Concepto**: examina las medidas de seguridad implementadas en redes y sistemas distribuidos, y destaca la complejidad y los riesgos asociados a este ambiente. Pone énfasis en la seguridad de las comunicaciones.
- **Funciones del Auditor**: revisa los aspectos lógicos y físicos; verifica el cumplimiento de las políticas y los perfiles de acceso de los usuarios; comprueba la seguridad de los componentes de la red de área local (LAN). Revisa las reglas y los controles de transmisión, verifica la seguridad del acceso remoto, revisa el hardware y el software de comunicación, y evalúa los planes de contingencia.
- **Elementos a auditar**: la arquitectura o topología de la red (anillo, bus, estrella); los componentes de la red (dispositivos, terminales, cables, software, servidores); la seguridad lógica (políticas, perfiles de acceso, autorización); la seguridad física (cableado, instalaciones); los controles ambientales; los controles de comunicación (seguridad de la transmisión, detección y corrección de errores, identificación de mensajes); la seguridad del acceso remoto; los planes de contingencia y recuperación, y los protocolos de red (TCP/IP).

5.2.4.6. Auditoría de sistemas (Capítulo 25)

- **Concepto**: implica la revisión y la evaluación de sistemas específicos, en particular de aquellos que presentan un alto riesgo, son problemáticos o en los que el control es difícil. Puede formar parte de una auditoría más amplia de sistemas de información.
- **Funciones del Auditor**: revisa y evalúa los sistemas; identifica y analiza los riesgos y las exposiciones; determina y clasifica los riesgos. Propone controles, verifica el cumplimiento de los controles y las políticas, y evalúa la efectividad de los controles. Planifica la auditoría y selecciona los sistemas que se auditarán según sus riesgos o problemas.

- **Elementos a auditar**: los sistemas (de aplicación general o específicos), los riesgos y exposiciones asociados, los controles (generales, de aplicación, internos), las políticas, los procedimientos, la documentación y el cumplimiento de las políticas y los procedimientos.

5.2.4.7. Auditoría del desarrollo de sistemas (Capítulo 23 en el índice y en el texto)

- **Concepto**: consiste en auditar los sistemas a lo largo de su ciclo de desarrollo. El objetivo es asegurar que los sistemas se desarrollen de acuerdo con los requerimientos establecidos y con controles internos adecuados.
- **Funciones del Auditor**: participa en la planificación y el diseño del sistema; verifica la definición de los requerimientos; evalúa el diseño técnico, lógico y físico; revisa la documentación. Participa en las pruebas (unitarias, de integración y del sistema), evalúa la implantación y realiza el seguimiento. Verifica la metodología utilizada y evalúa los riesgos asociados al desarrollo.
- **Elementos a auditar**: la metodología de desarrollo; la definición de los requerimientos; el diseño lógico y físico; la documentación (diagramas, diccionarios de datos, etc.); los programas o el código; las pruebas (planes, resultados, evidencia); el proceso de implantación; el plan del proyecto, y los controles diseñados dentro del sistema.

5.2.4.8. Auditoría de adquisición de software (Capítulo 26 en el texto)

- **Concepto**: auditoría del proceso mediante el cual una organización adquiere software. Busca asegurar una selección apropiada y términos contractuales adecuados.
- **Funciones del Auditor**: revisa el proceso de adquisición; verifica la solvencia y el soporte del proveedor; revisa los contratos; examina la documentación; verifica las pruebas y la satisfacción del usuario.
- **Elementos a auditar**: el proceso de adquisición de software, la solvencia y el soporte del proveedor, los contratos, la documentación del software, las pruebas y la satisfacción del usuario, y las licencias de uso.

5.2.4.9. Auditoría de modificaciones a programas (Capítulo 26 en el texto)

- **Concepto**: auditoría de los cambios realizados a programas existentes. Asegura que las modificaciones estén autorizadas, documentadas y probadas adecuadamente.
- **Funciones del Auditor**: revisa el proceso de modificación; verifica la autorización y la documentación de los cambios; comprueba los procedimientos de prueba; verifica el control de las bibliotecas de programas (*librarian control*).
- **Elementos a auditar**: el proceso de modificación de programas, los registros de autorización, la documentación de los cambios, la evidencia y los resultados de las pruebas, el control de las bibliotecas de programas y la segregación de funciones en el proceso de modificación.

5.2.4.10. Auditoría de sistemas instalados de aplicación (Capítulo 26 en el texto)

- **Concepto**: auditoría de los sistemas de aplicación que ya están instalados y en operación. Se enfoca en identificar y evaluar sus fortalezas y debilidades.
- **Funciones del Auditor**: identifica y evalúa las fortalezas y debilidades; verifica la aplicación de los controles y los evalúa en función de los objetivos. Analiza la eficiencia y verifica el cumplimiento. Realiza pruebas. Revisa los controles de entrada, procesamiento, salida y archivos/base de datos, y las operaciones en distintos ambientes (centralizado, distribuido, en línea, *batch*). Realiza auditorías específicas de módulos como Compras/Recepción, Cuentas a Pagar, Ventas, Cobranzas, Remuneraciones, Administración de Inventarios y Bienes de Uso.
- **Elementos a auditar**: los sistemas de aplicación instalados; sus controles (de entrada, procesamiento, salida y archivos/base de datos) [198, 199-385; detalles exhaustivos sobre los controles de entrada de datos]; la integridad y la exactitud de los datos; la seguridad de las transacciones; el cumplimiento de los procedimientos; la eficiencia del sistema, y los controles de validación de datos.

5.2.4.11. Auditoría de control de entrada de datos (dentro del Capítulo 26, página 382)

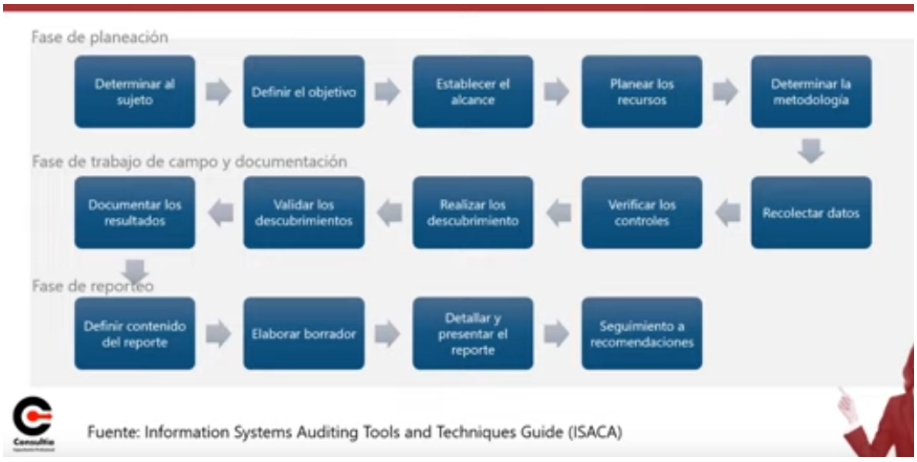
- **Concepto**: auditoría de los controles específicos relacionados con la entrada de datos a los sistemas. El objetivo es asegurar la exactitud, la integridad y la autorización de los datos que ingresan, y el cumplimiento de las políticas y los procedimientos correspondientes. Incluye las transacciones ingresadas en línea y los datos transmitidos a distancia.
- **Funciones del Auditor**: verificar la exactitud, la integridad y la autorización de los datos, y la seguridad de las transacciones. Evaluar la eficiencia del sistema. Asegurar el cumplimiento de los procedimientos. Observa las operaciones, revisa la documentación, comprueba los procedimientos de validación y realiza pruebas de entrada de datos remota.
- **Elementos a auditar**: los procesos de entrada de datos; los controles de exactitud, integridad y autorización de los datos; la seguridad de las transacciones; la eficiencia del sistema; el cumplimiento de los procedimientos y las políticas; las reglas y los procedimientos de validación de datos; la documentación relacionada; el formato y el contenido de los datos; los registros o *logs* de transacciones, y el control de las transacciones en línea y de los datos transmitidos a distancia.

5.2.5. Auditoría del desarrollo: efectúe un cuadro comparativo entre el enfoque de Lardent y el de Piattini & Del Peso

El enfoque de Mario Piattini sobre la **auditoría del desarrollo** de software se centra en varios aspectos clave, basados principalmente en los principios de control interno y en la calidad del proceso de desarrollo:

- **Auditoría como verificación de controles**: Piattini define la auditoría del desarrollo como un proceso de verificación de la existencia y la aplicación de procedimientos de control adecuados, para garantizar que el desarrollo de los sistemas de información se realice conforme a principios sólidos de ingeniería de software.

- **Cobertura del ciclo de vida del software**: la auditoría del desarrollo incluye todo el ciclo de vida del software (análisis, diseño, construcción e implantación), pero no considera las fases de explotación, mantenimiento o retirada del servicio.
- **Metodología basada en ISACA**: Piattini adopta el enfoque de evaluación de riesgos propuesto por la ISACA. Parte de los riesgos potenciales y define objetivos de control específicos, asociados a técnicas y pruebas de cumplimiento.



> Observar la fuente (ISACA).

- **Doble foco**: la auditoría se divide en:
  - Auditoría de la organización y gestión del área de desarrollo.
  - Auditoría de los proyectos de desarrollo, con especial énfasis en la calidad del desarrollo de los sistemas de información.
- **Importancia de la organización**: Piattini recalca que no solo se auditan las tareas técnicas, sino también la gestión organizativa que asegura el éxito de los proyectos.
- **Adaptación a la organización y al proyecto**: los objetivos y los niveles de cumplimiento no se consideran un modelo cerrado; el auditor debe adaptarlos a las particularidades de cada organización y proyecto.

En resumen, el enfoque de Piattini combina la perspectiva técnica y la organizativa, y destaca la necesidad de controles de calidad y de gestión de riesgos durante todo el ciclo de vida del desarrollo.

> En el apunte original estaba explicado el enfoque de Piattini solamente. A continuación, agregué un cuadro comparativo con el enfoque de Lardent también:

5.2.5.1. Cuadro comparativo: Auditoría del Desarrollo de Sistemas (Lardent vs. Piattini & Del Peso)

Criterio de comparación	Enfoque de Alberto R. Lardent	Enfoque de Mario Piattini y Emilio del Peso
Objetivo principal	Identificar, analizar y evaluar los requerimientos del usuario, los riesgos, las exposiciones a riesgos y los **puntos de control** que deben incorporarse a los sistemas de aplicación durante las fases de desarrollo para asegurar que cumplan con los requisitos del negocio.	Comprobar la existencia de **procedimientos de control interno** y verificar su correcta definición y aplicación según principios sólidos de **Ingeniería de Software**, determinando las deficiencias de control existentes y los riesgos asociados.
Nivel de estructuración y flexibilidad	**Más flexible y general:** Plantea un conjunto de acciones y propuestas generales sin imponer el «cómo» estricto; el auditor decide dónde poner el foco. Por eso se adapta más fácilmente tanto a metodologías clásicas como a marcos ágiles.	**Muy estructurado, técnico y detallado:** Define procedimientos y guías claras paso a paso (asociado a metodologías tradicionales en cascada derivadas de normas ISO, como *Métrica v3*), apoyándose en herramientas y listas de verificación para cada etapa.
Mirada y foco principal	Se enfoca más en el **marco institucional, administrativo y organizacional** del desarrollo, con la mirada puesta en la productividad, la relación costo-beneficio (justificación económica), el planeamiento estratégico y los aspectos normativos.	Combina una **perspectiva técnica de ingeniería de software y de gestión organizativa** («Doble foco»), centrada en la calidad del software para evitar los altos costos de mantenimiento y el fracaso de proyectos (*crisis del software*).
Metodología de auditoría utilizada	Se basa en la determinación de **puntos de control** clave insertos en el cuerpo del sistema y a lo largo de las fases del proyecto, junto con la incorporación de **módulos y pistas de auditoría** para facilitar futuras revisiones de rutina.	Aplica formalmente la **metodología de evaluación de riesgos de ISACA**: parte de los riesgos potenciales de la actividad y sigue el esquema jerárquico: N **Objetivos de Control** $\rightarrow$ **Técnicas de Control (`C-X-m`)** $\rightarrow$ **Pruebas de Cumplimiento**.

Criterio de comparación	Enfoque de Alberto R. Lardent	Enfoque de Mario Piattini y Emilio del Peso
Cobertura y división del alcance	**Abordaje amplio en 4 niveles** (incluye etapas previas y posteriores a la construcción): 1. **Revisión del ciclo de vida:** Parte del *Plan Maestro de SI/TI*, el *Estudio de Factibilidad* y recorre las fases desde análisis de requerimientos hasta la **Posinstalación (mantenimiento)**. 2. **Auditoría de la documentación de sistemas:** Documentos exigidos por etapa. 3. **Auditoría de adquisición de software:** Solvencia del proveedor, contratos, recupero/propiedad del código fuente y soporte. 4. **Auditoría de modificación de programas:** Autorización, trazabilidad del cambio y concordancia entre código fuente y objeto.	**Abordaje dividido en 2 grandes bloques (Doble foco)**, acotado al ciclo de desarrollo puro (abarca análisis, diseño, construcción e implantación, pero **excluye** explotación, mantenimiento y retiro, que se tratan en capítulos aparte): 1. **Auditoría de la organización y gestión del área de desarrollo:** Cómo se administra y trabaja el personal (propone 8 objetivos de control divididos en niveles de la A a la G). 2. **Auditoría de proyectos de desarrollo de SI:** Aprobación, planificación, gestión y calidad de cada proyecto específico según sus riesgos, complejidad y recursos.
Rol del auditor e independencia	Cumple un **papel activo de consultoría/asesoría** trabajando a la par del equipo durante las fases del ciclo de vida para definir los puntos de control y rastros de auditoría. Para no perder objetividad ni independencia, **la persona que luego audite el sistema en posinstalación/producción debe ser distinta de la que ayudó a definir los puntos de control**.	Actúa como una función evaluadora e independiente que **verifica la existencia y el grado de cumplimiento** de los objetivos y controles ya establecidos por la organización, recolectando evidencias mediante pruebas de cumplimiento (o exámenes más profundos y muestreo cuando se requiere) para identificar puntos fuertes, débiles y riesgos no cubiertos.

5.2.5.1.1. Síntesis para recordar en el examen

- **Lardent** piensa en el auditor metido en el proyecto como un **asesor preventivo** que se asegura de que haya un *Plan Maestro*, un *Estudio de Factibilidad* rentable y que se planten **puntos de control**

y pistas de auditoría adentro del software antes de que salga a la calle (cubriendo además qué pasa si el software se compra hecho o si se modifica en mantenimiento).

- **Piattini & Del Peso** miran el desarrollo desde la **Ingeniería del Software y la metodología ISACA**, separando la auditoría en dos mitades (**1. Cómo está organizado el departamento de desarrollo** y **2. Cómo se gestiona y construye cada proyecto en sí**), dándole al auditor una **guía estructurada de Objetivos de Control, Técnicas y Pruebas de Cumplimiento** desde el análisis hasta la implantación.